Mapping RBAC in BloodHound

Hope Walker
Senior Security Researcher

Introduction

- Senior Security Researcher – SpecterOps
  - Focus on Azure/Entra ID
- 10 years of offensive security experience
- Prior
  - Consulting – Adversary Simulation (SpecterOps)
  - DoD – Long-term Red Teaming
- Teaching
  - Created Active Directory and Azure/Entra courses (SpecterOps)
- Hobby collector
  - Hiking, crochet, sewing, creative writing, archery, video games, music, gardening, cooking

Agenda

- RBAC Refresher
- How roles are mapped in BloodHound?
- The Problem
  - Issues and short falls with old approach
- The Solution
  - New method for mapping RBAC
- Final Thoughts
  - Long-term vision
  - Where is it at now?

RBAC Refresher

RBAC Refresh

- May be familiar with Windows systems and permission granting
- Discretionary Access Control (DAC)
  - Assign permissions on resources to grant permissions
  - Can be inconsistent
  - Hard to manage and audit

RBAC Refresh

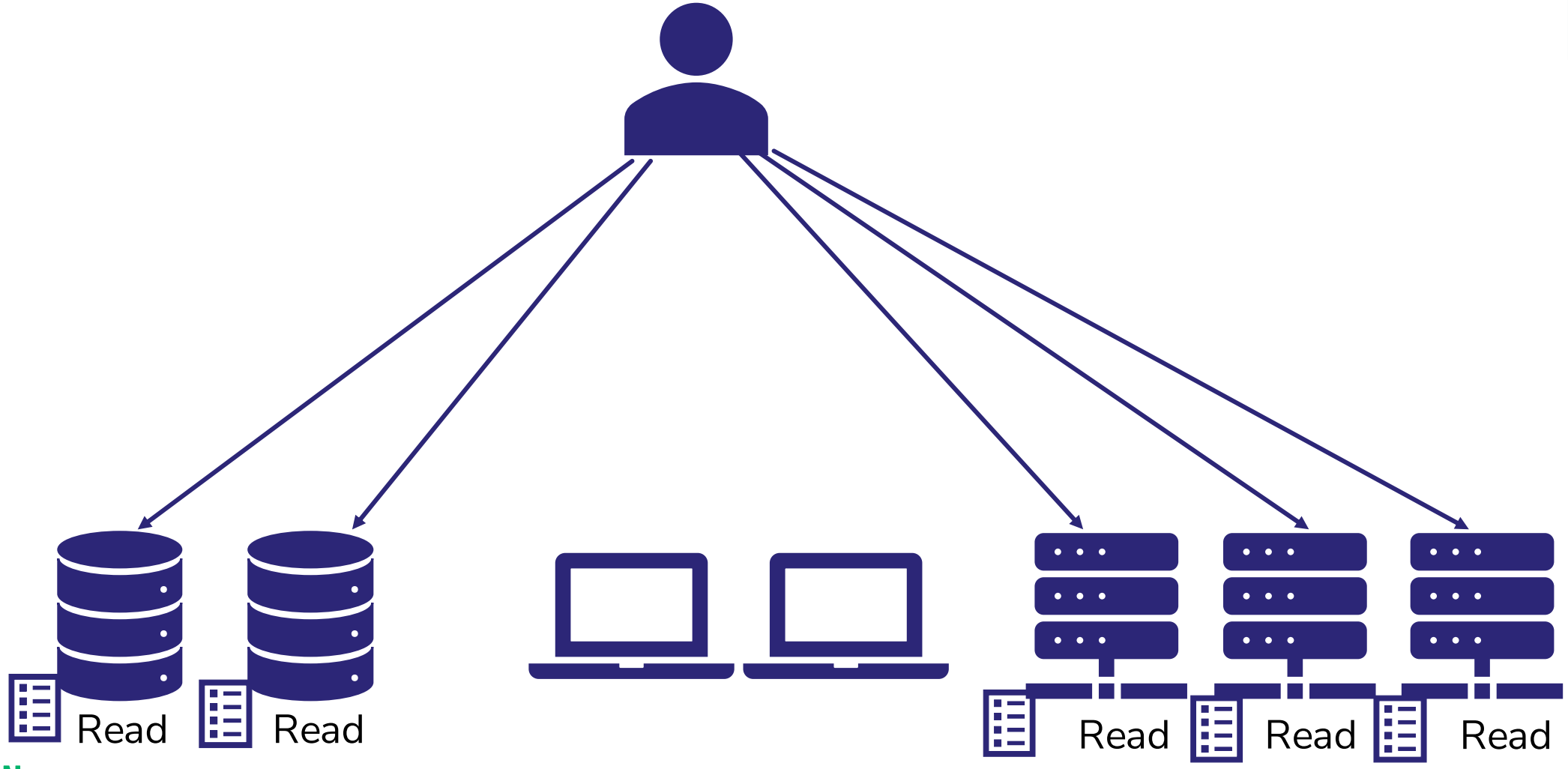
- Role based access control (RBAC)
- Method for access control to resources
- Roles are:
  - Based on job function
  - Collection of permissions
  - Assigned to principals
  - Enable access and ability to make changes

RBAC Refresh – Benefits

- Allows for more granular control of access
- Easier management
  - Setup and granted permissions for specific job roles
  - Consistent permissions granted
  - Role assignments are associated with users instead of on individual resources

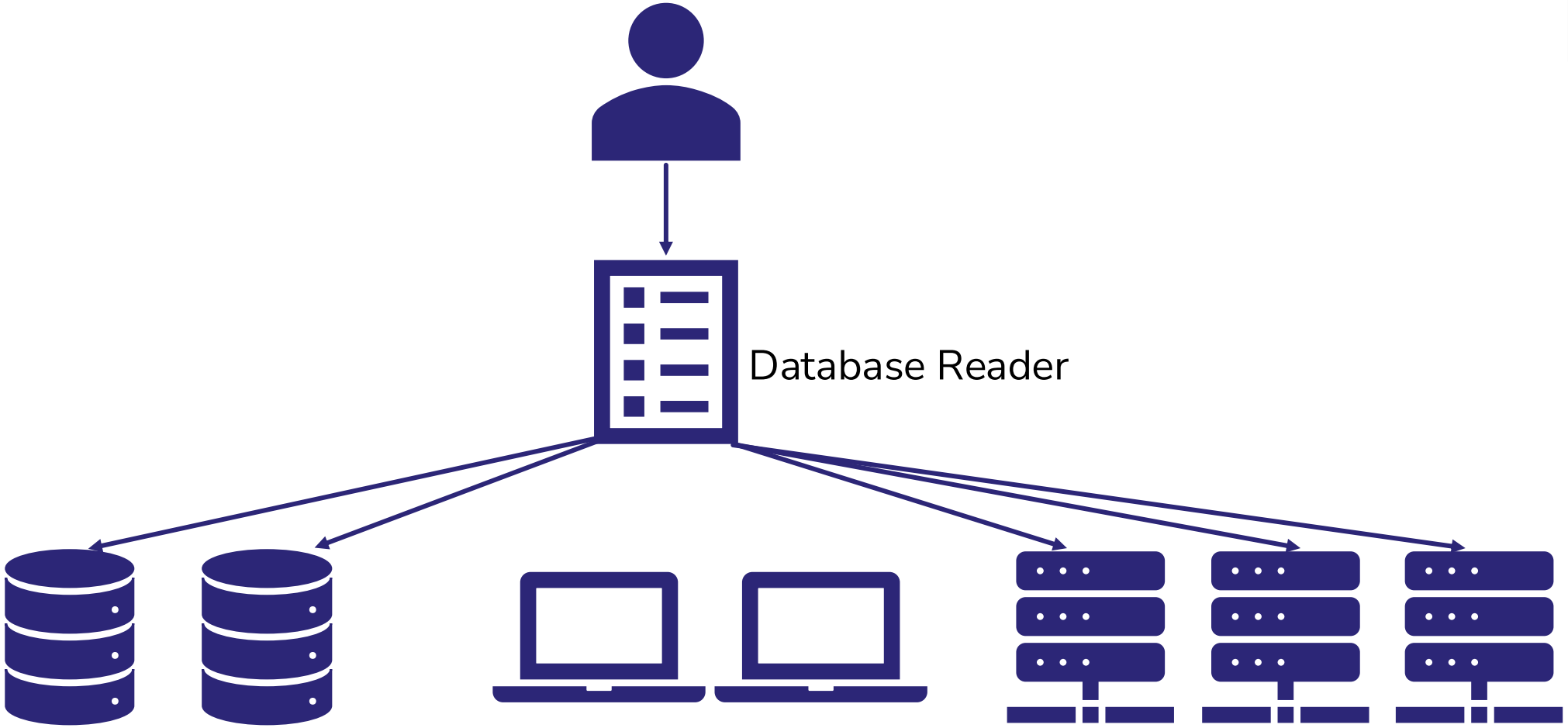
RBAC Refresh – Benefits

Discretionary Access Control



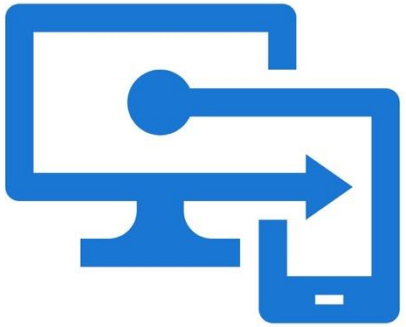
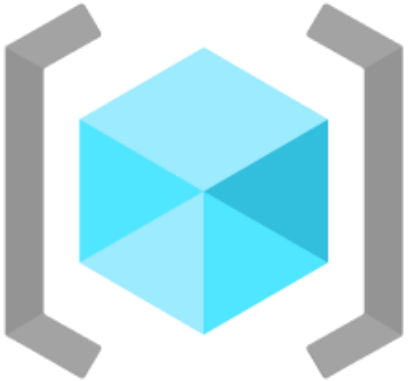
RBAC Refresh – Benefits

Role Based Access Control



RBAC Refresh – Microsoft Cloud Services

- Entra ID, MS Graph, Azure RM, Intune, and many other services in the Microsoft ecosystem are set up to use RBAC
  - Roles are required for most actions beyond reading basic information

Entra RBAC

Our friendly example for this talk

Role permissions

microsoft.directory/applications/createAsOwner	
microsoft.directory/oAuth2PermissionGrants/createAsOwner	PRIVILEGED
microsoft.directory/servicePrincipals/createAsOwner	

Application Developer | Description

Privileged Identity Management | Microsoft Entra roles

Got feedback?

Summary

Name: Application Developer PRIVILEGED

Description: Users in this role will continue to be able to register app registrations even if the Global Admin has turned off the tenant level switch for "Users can register apps".
This role is considered privileged because one or more of its permissions are privileged. Learn more

Template ID: cf1c38e5-3621-4004-a7cb-879624dced7c

Related articles: Assigning administrator roles in Microsoft Entra ID

Role permissions

microsoft.directory/applications/createAsOwner		Create all types of applications, and creator is added as the first owner
microsoft.directory/oAuth2PermissionGrants/createAsOwner	PRIVILEGED	Create OAuth 2.0 permission grants, with creator as the first owner
microsoft.directory/servicePrincipals/createAsOwner		Create service principals, with creator as the first owner

This role also grants the following basic read permissions to guests and service principals

microsoft.directory/administrativeUnits/members/read	Read members of administrative units
microsoft.directory/administrativeUnits/standard/read	Read basic properties on administrative units
microsoft.directory/applicationPolicies/standard/read	Read standard properties of application policies
microsoft.directory/applications/owners/read	Read owners of applications
microsoft.directory/applications/policies/read	Read policies of applications

Entra RBAC

Permission representation

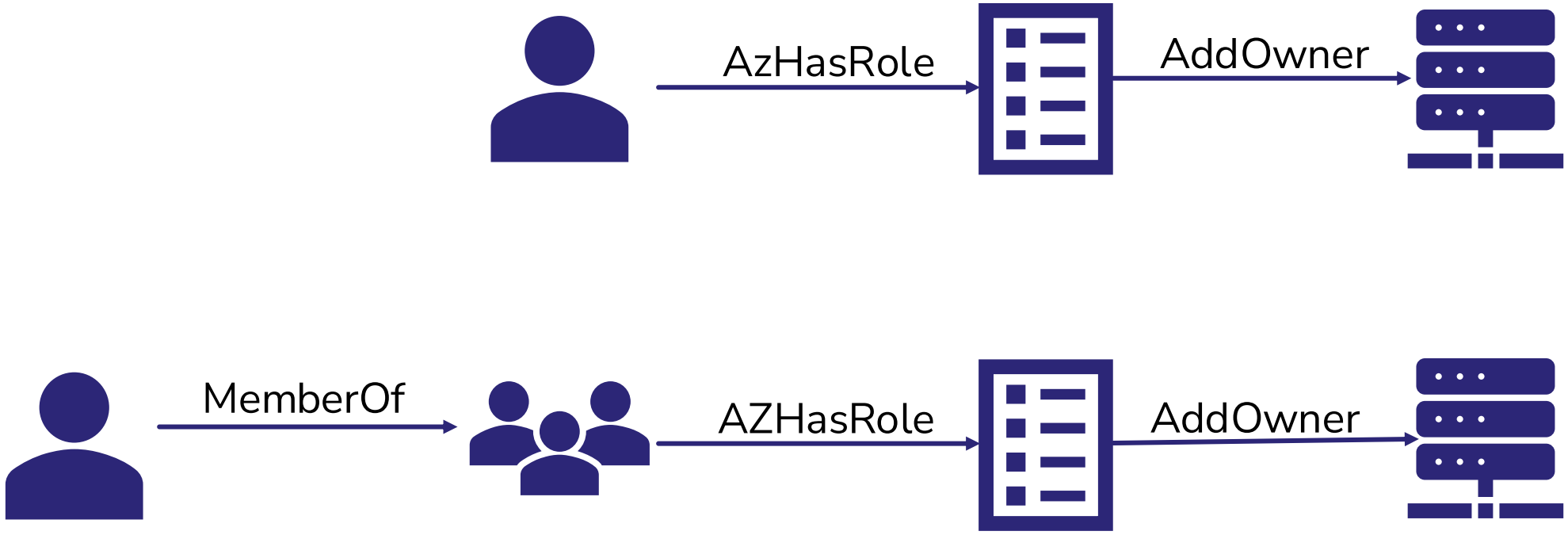
- Permissions are (generally) formatted as:
  - *{Provider} / {Resource Type} / {Action}*
- For example:
  - *microsoft.directory/applications/create*
    - Permission for creating new application
    - *Microsoft.directory* = Entra ID permission

How Are Roles Mapped?

How Are Roles Mapped?

Under the Hood

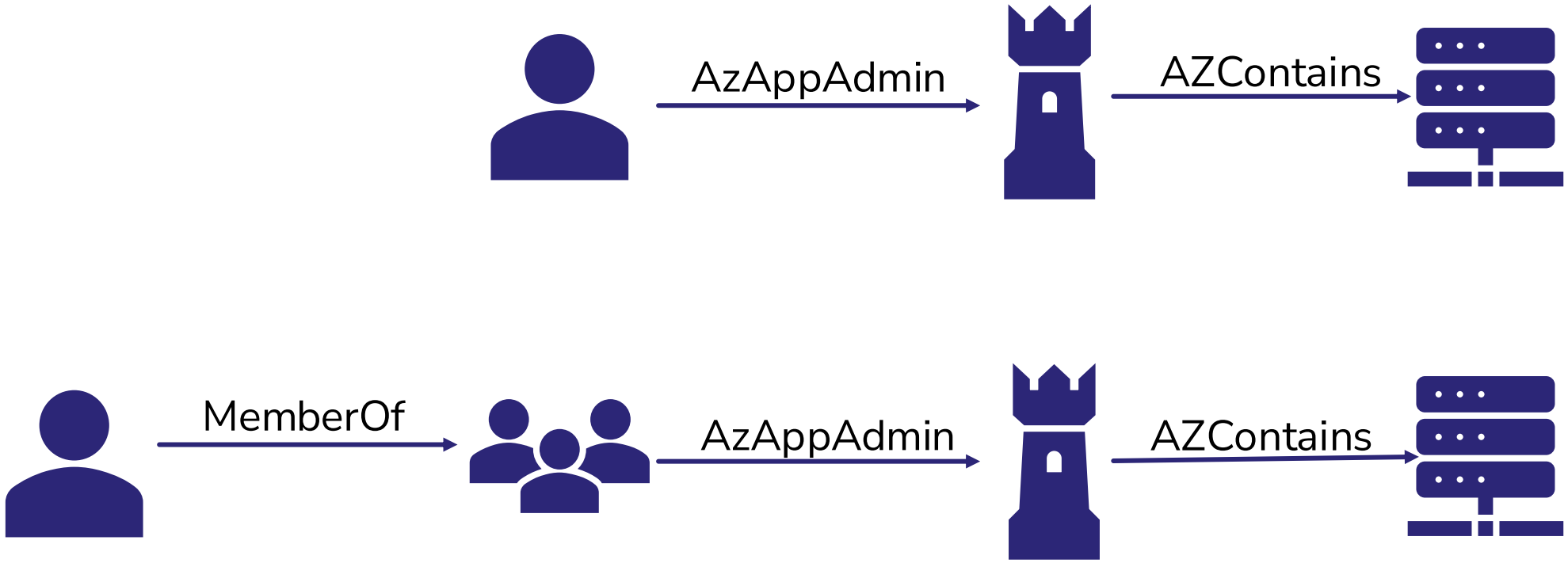
- Users or groups are connected to roles then connected to the resource



How Are Roles Mapped?

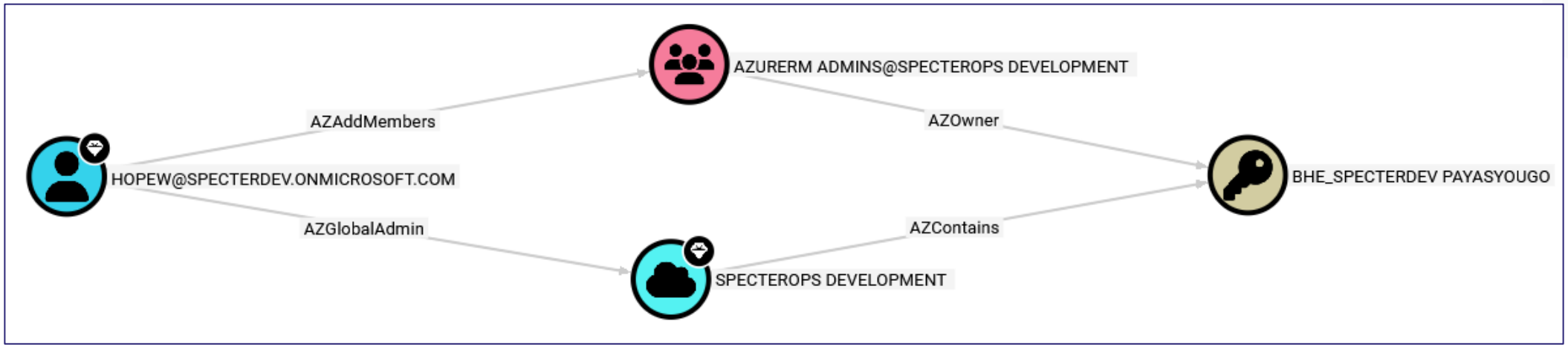
What was displayed

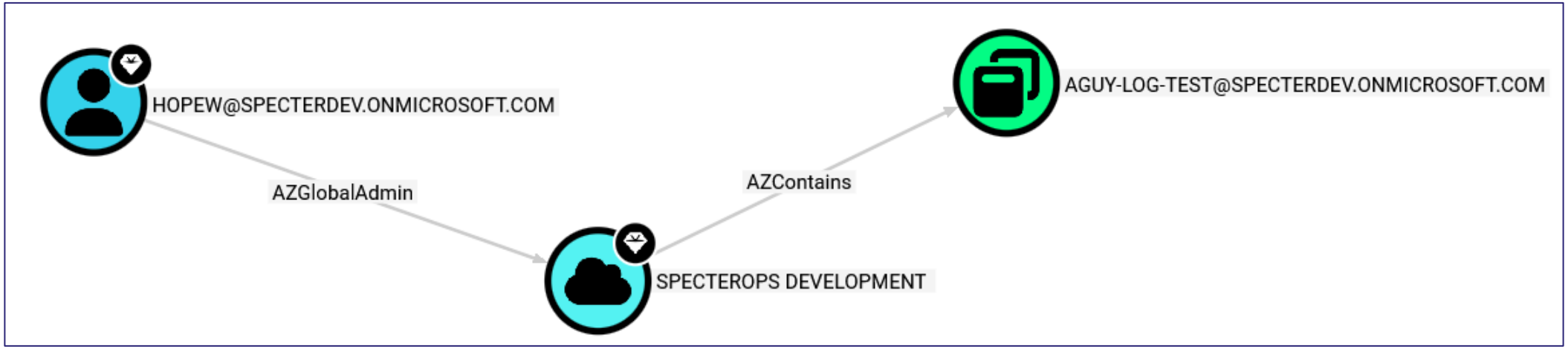
- These were consolidated into edges, but still went through scope node



How Are Roles Mapped?

What was displayed





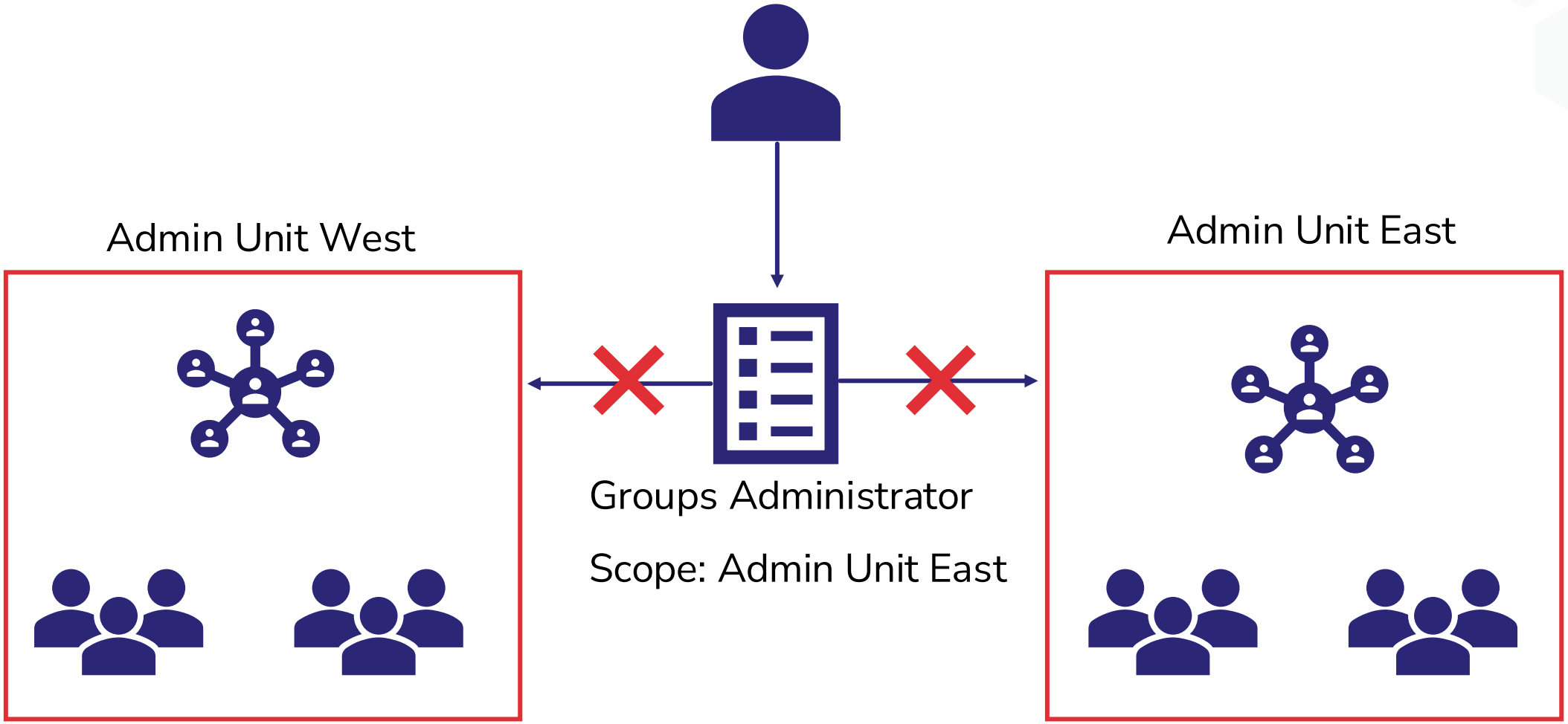
How Are Roles Mapped?

Limited support for scoping

- Most role assignments are for the entire scope of the directory
- However, system also allow for scoped assignments
  - Role assignments that only affect a subset of the resource type
- Example:
  - Administrative Units in Entra ID
  - Role assignments for a single application

How Are Roles Mapped?

Limited support for scoping



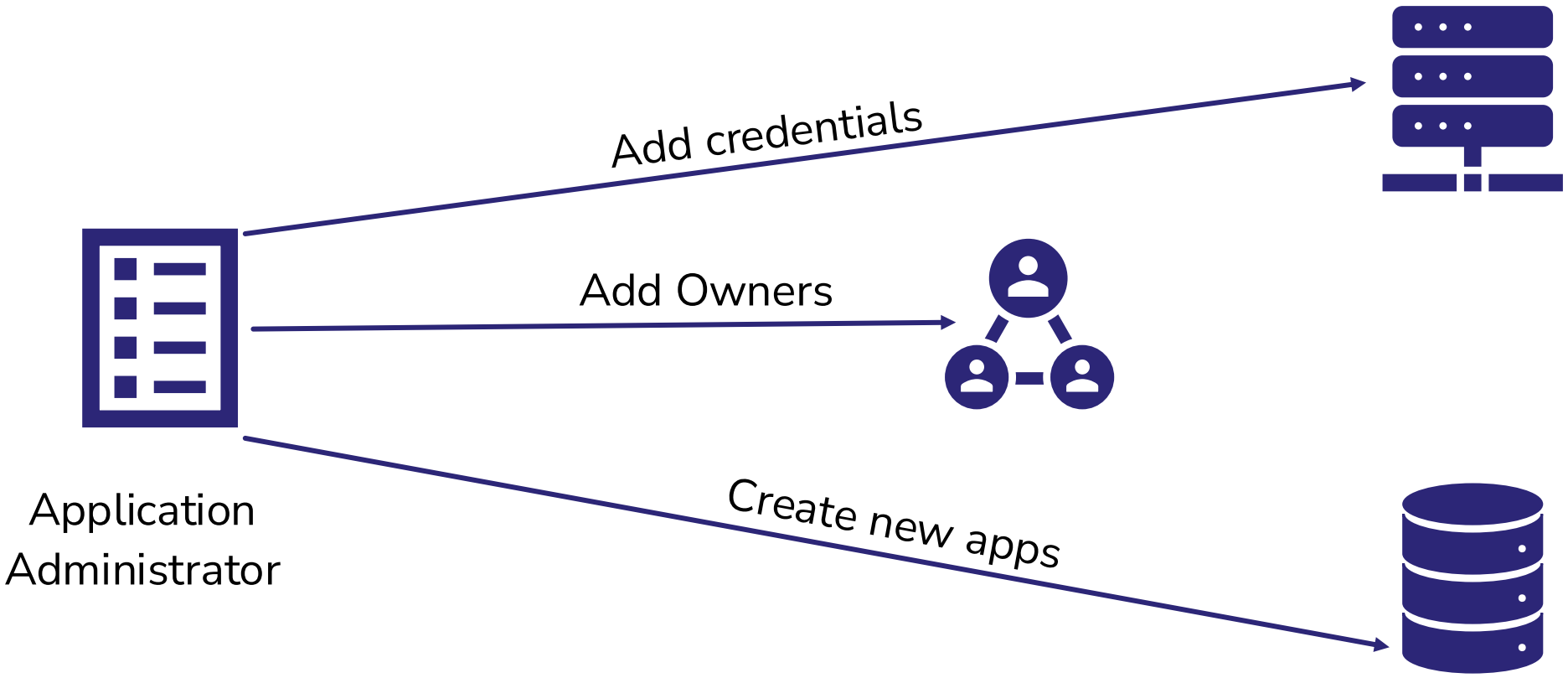
How Are Roles Mapped?

How do we connect it to a resource?

- Roles mapping has historically been done based on what is known about the role
  - What specific actions do we know this role allows?
    - Read, write, delete, etc. on a specific resource or resource type
  - What have we observed with this role?
    - What attacks have occurred using this role?
    - What research has been conducted about this role?
  - Microsoft documentation is not always accurate

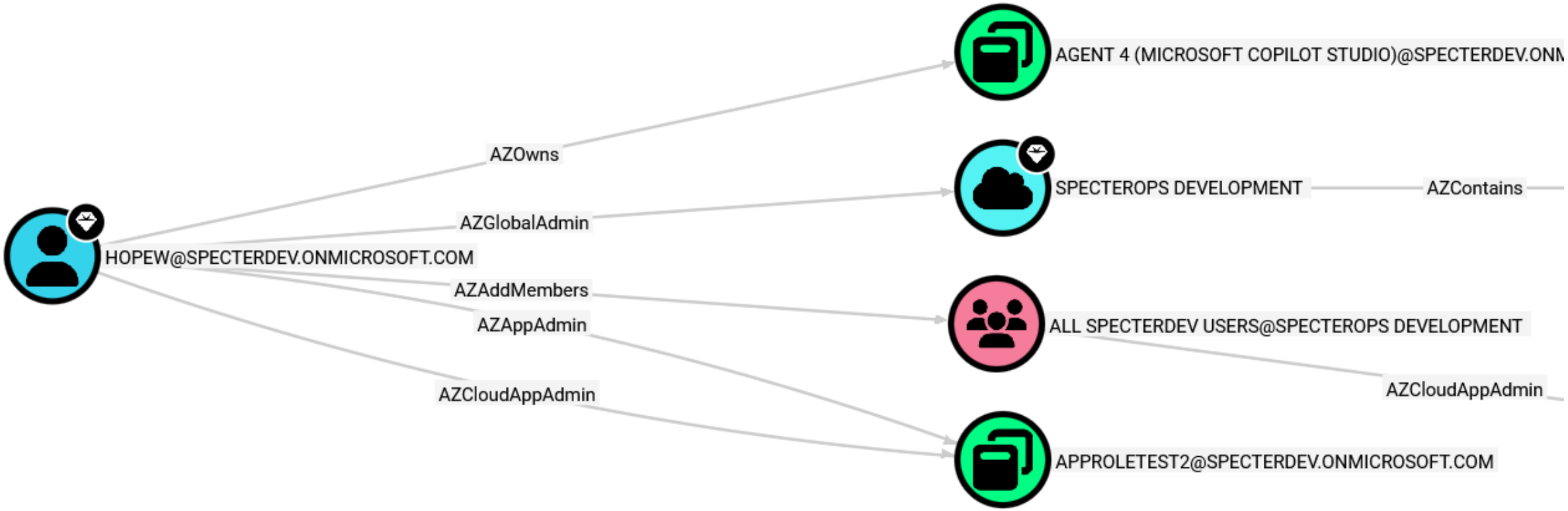
How Are Roles Mapped?

Mapped based on what we know is possible



How Are Roles Mapped?

What was displayed?



The Problem

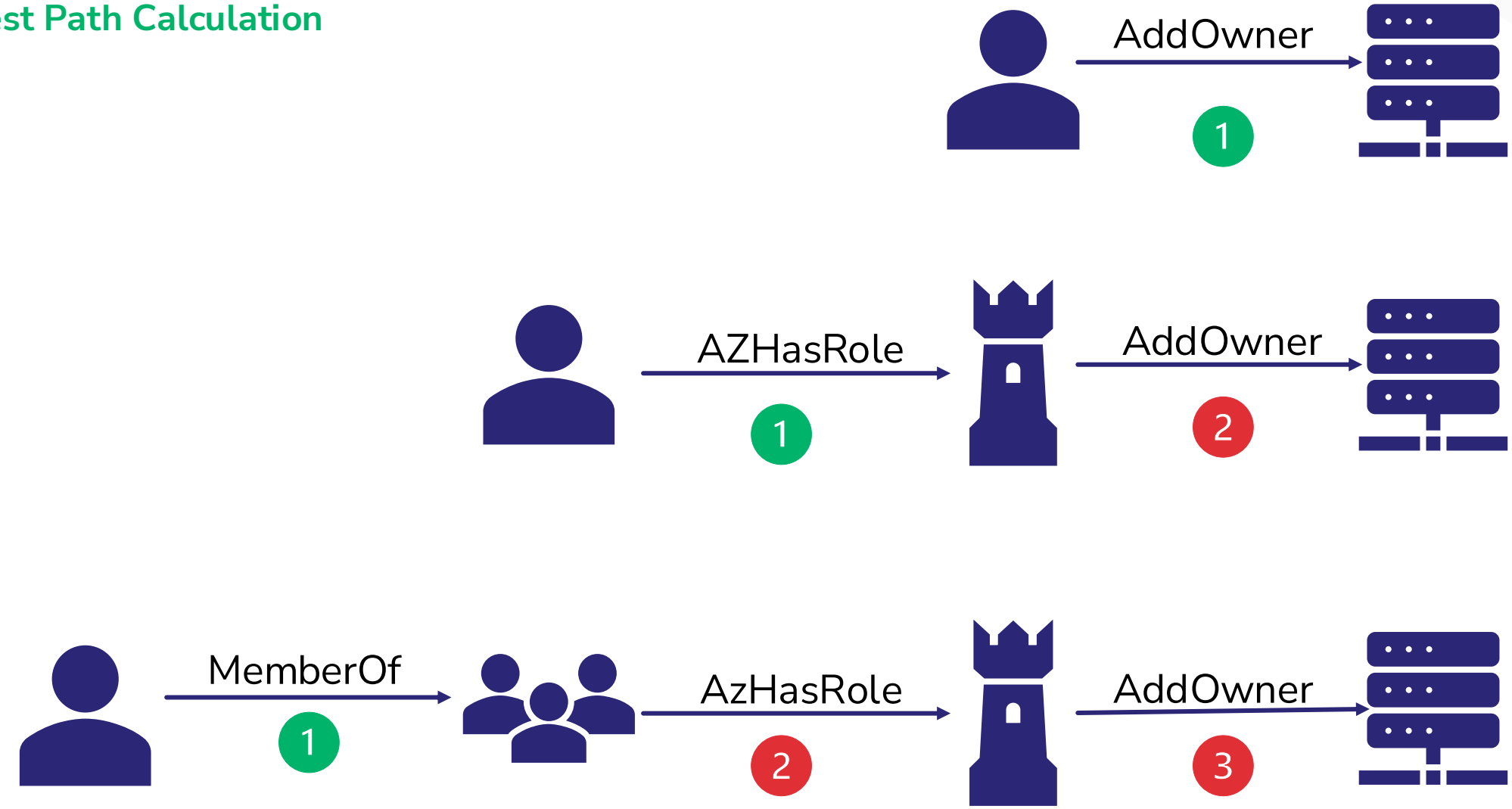
The Problem

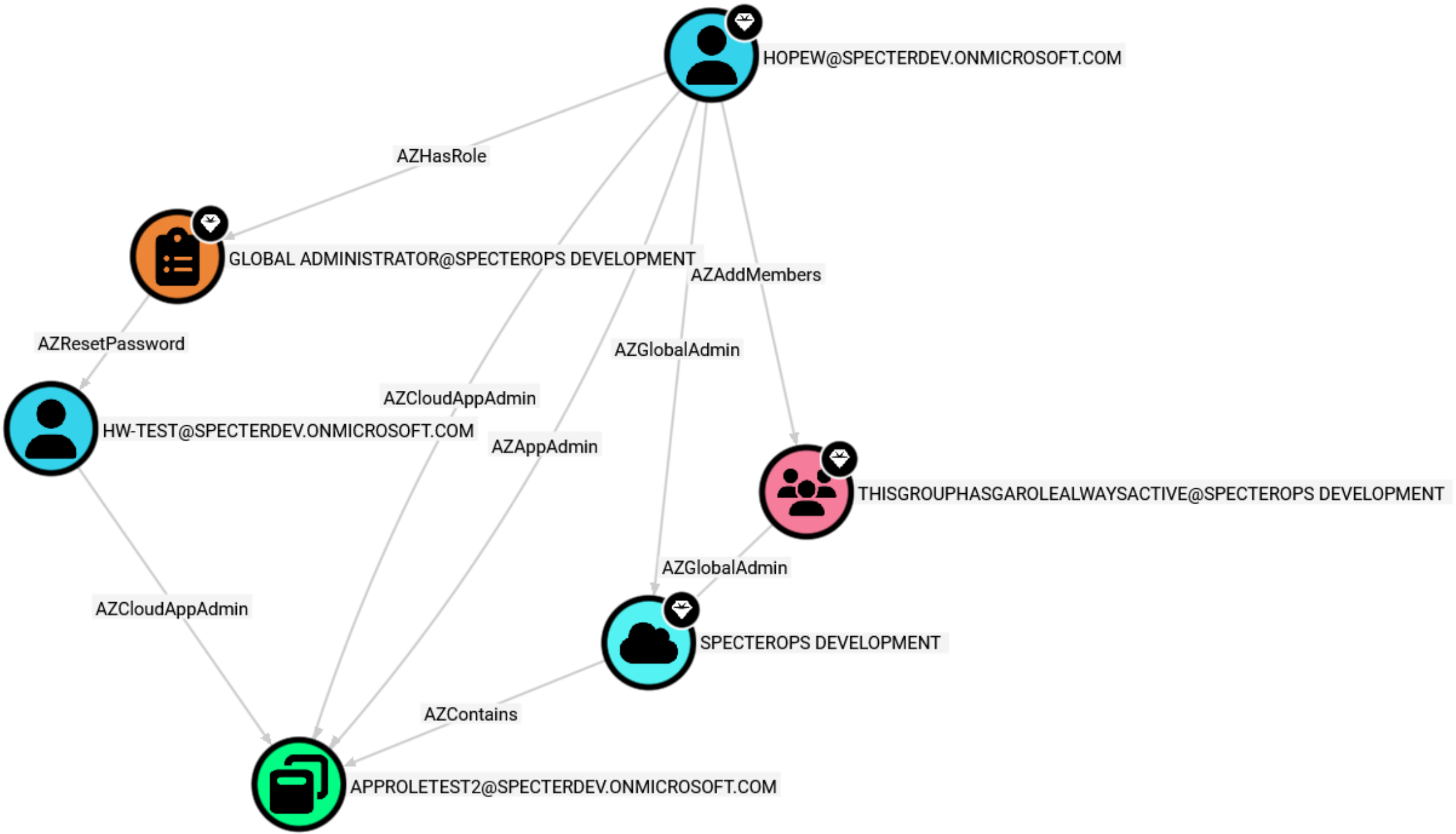
Shortest Path Calculation

- Role is represented as a node
  - Shows that the user has the role assigned
- Relationship is represented as a traversable edge
  - Shows that the reason the user has the permission is because of the role
- Additional node for scope which means **shorter paths may not be found**
- Can't connect directly to resource because there is not a good indication of where the role comes from

The Problem

Shortest Path Calculation




HOPEW@SPECTERDEV.ONMICROSOFT.COM
AZHasRole
GLOBAL ADMINISTRATOR@SPECTEROPS DEVELOPMENT
AZAddMembers
AZResetPassword
AZGlobalAdmin
AZCloudAppAdmin
HW-TEST@SPECTERDEV.ONMICROSOFT.COM
AZAppAdmin
THISGROUPHASGAROLEALWAYSACTIVE@SPECTEROPS DEVELOPMENT
AZGlobalAdmin
AZCloudAppAdmin
SPECTEROPS DEVELOPMENT
AZContains
APPROLETEST2@SPECTERDEV.ONMICROSOFT.COM

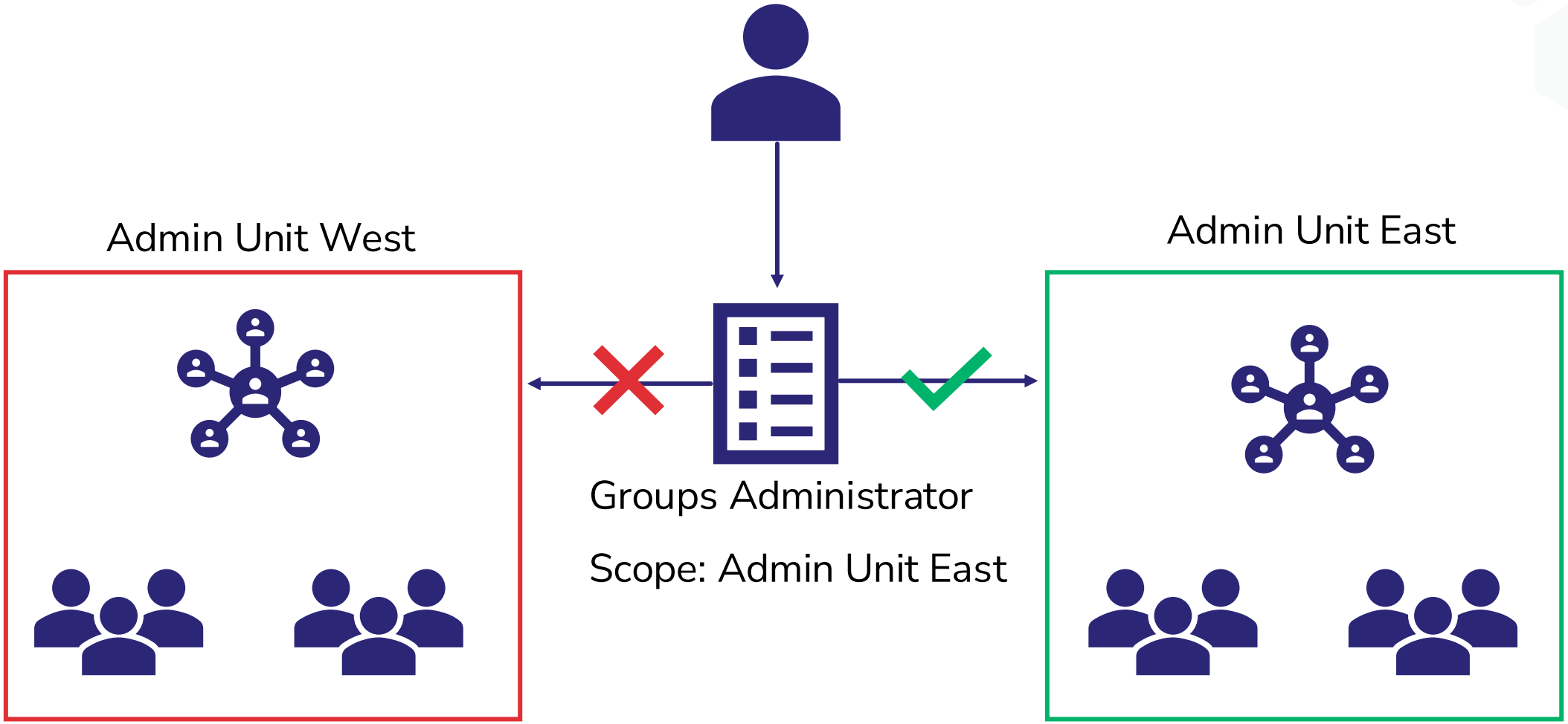
The Problem

Limited support for scoping

- Role assignments that affect a limited subset of resources may not be represented at all
- Need to be able to show assignments that are scoped
- Problems may still exist when read permissions are limited
  - Example: Hidden Administrative Units
  - Will partially depend on the context used during collection

The Problem

Limited support for scoping



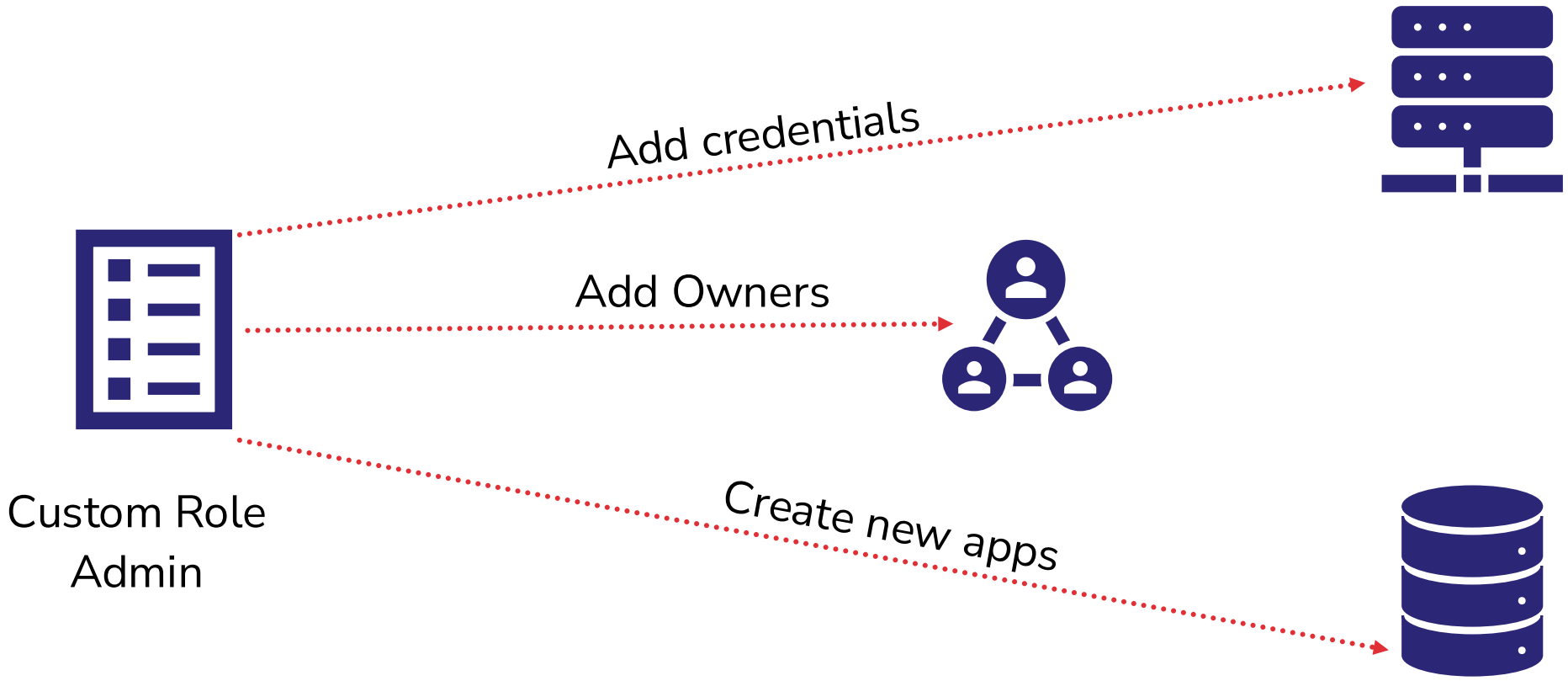
The Problem

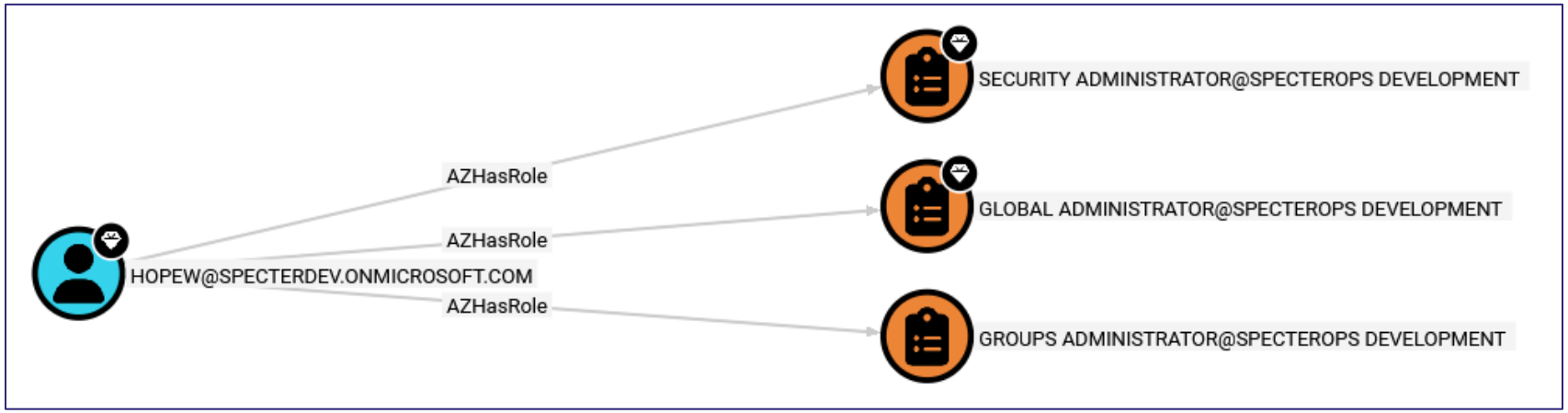
Limited support for custom roles

- Edges are drawn based on what is known about the role
- Custom roles can vary widely between environments
  - Would have to be added manually or they are not represented
  - Dangerous because these can easily be overprivileged and overprovisioned

The Problem

Limited support for custom roles





Home › SpecterOps Development | Users › Users › Hope Walker

Hope Walker | Assigned roles

User

Search

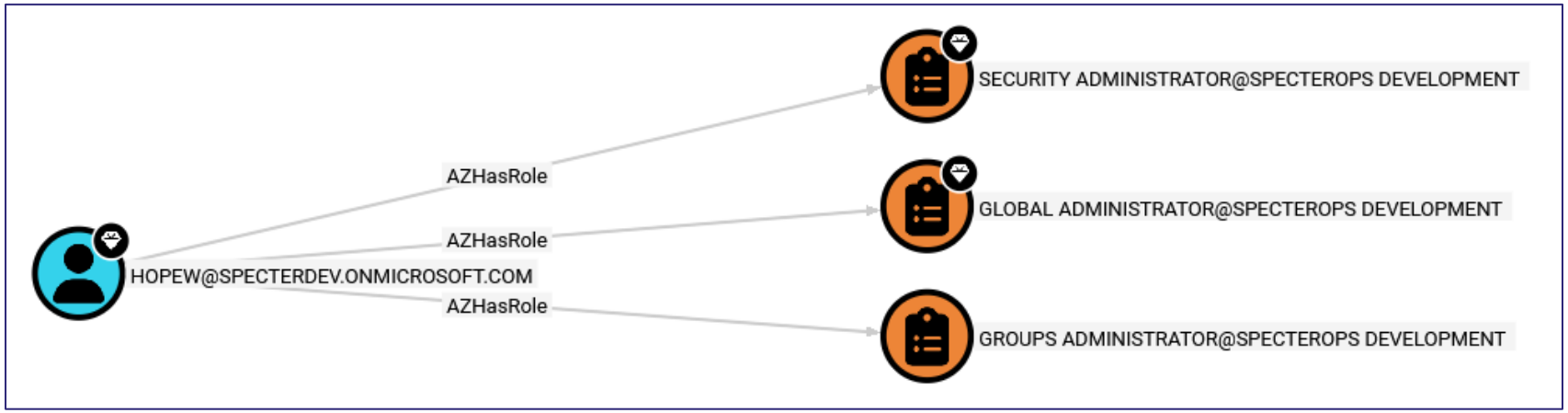
- Overview
- Audit logs
- Sign-in logs
- Diagnose and solve problems
- Custom security attributes
- Assigned roles
- Administrative units
- Groups
- Applications
- Licenses
- Devices

Add assignments | Refresh | Got feedback?

Eligible assignments | **Active assignments** | Expired assignments

Search by role

Role	Principal name	Scope	Membership	State	Start time	End time
Global Administrator	hopew@specterdev....	Directory	Direct	Active	1/3/2024, 7:24:53 PM	Permanent
Application Administ...	hopew@specterdev....	approletest2 (Service principal)	Direct	Active	12/11/2025, 10:58:02...	Permanent
Security Administrator	hopew@specterdev....	Directory	Direct	Active	7/20/2023, 12:48:58 ...	Permanent
PIMTestRole	hopew@specterdev....	Directory	Direct	Active	4/8/2026, 2:57:36 PM	10/5/2026, 2:57:07 PM
Cloud Application A...	hopew@specterdev....	approletest2 (Application)	Direct	Active	12/11/2025, 10:57:10...	Permanent
Cloud Application A...	hopew@specterdev....	ThisSPOwnsTheGAGroup (Service principal)	Group	Active	4/18/2022, 3:46:53 PM	Permanent
Groups Administrator	hopew@specterdev....	HWTestAURestricted (Administrative unit)	Direct	Active	-	Permanent



Home › SpecterOps Development | Users › Users › Hope Walker

Hope Walker | Assigned roles

User

Search

- Overview
- Audit logs
- Sign-in logs
- Diagnose and solve problems
- Custom security attributes
- **Assigned roles**
- Administrative units
- Groups
- Applications
- Licenses
- Devices

Add assignments | Refresh | Got feedback?

Eligible assignments | **Active assignments** | Expired assignments

Search by role

Role	Principal name	Scope	Membership	State	Start time	End time
Global Administrator	hopew@specterdev....	Directory	Direct	Active	1/3/2024, 7:24:53 PM	Permanent
~~Application Administ...~~	hopew@specterdev....	approletest2 (Service principal)	Direct	Active	12/11/2025, 10:58:02...	Permanent
Security Administrator	hopew@specterdev....	Directory	Direct	Active	7/20/2023, 12:48:58 ...	Permanent
~~PIMTestRole~~	hopew@specterdev....	Directory	Direct	Active	4/8/2026, 2:57:36 PM	10/5/2026, 2:57:07 PM
~~Cloud Application A...~~	hopew@specterdev....	approletest2 (Application)	Direct	Active	12/11/2025, 10:57:10...	Permanent
~~Cloud Application A...~~	hopew@specterdev....	ThisSPOwnsTheGAGroup (Service principal)	Group	Active	4/18/2022, 3:46:53 PM	Permanent
Groups Administrator	hopew@specterdev....	HWTestAURestricted (Administrative unit)	Direct	Active	-	Permanent

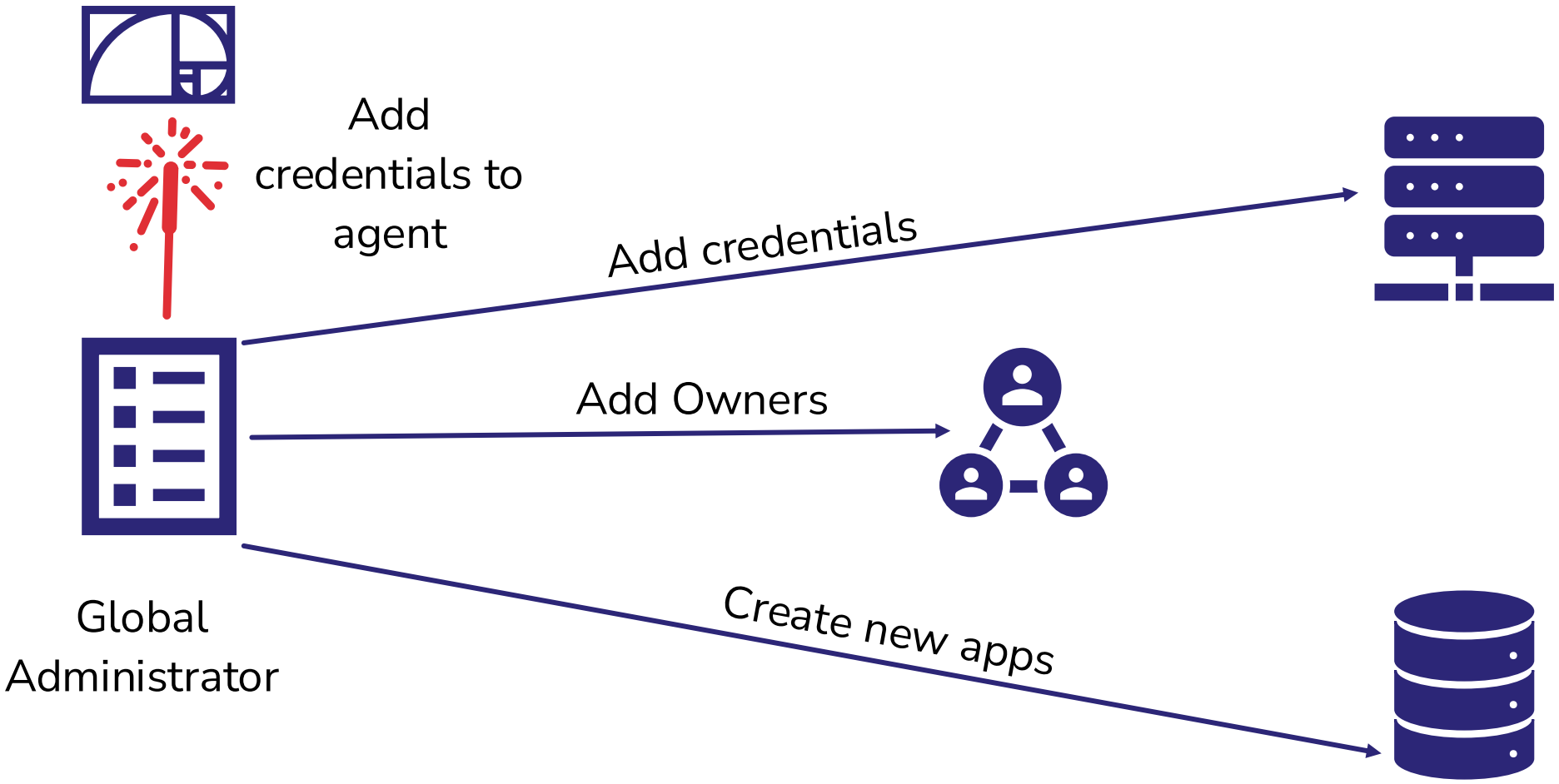
The Problem

Limited support for changes

- Static representation of the roles
  - As more permissions are added or removed these are not reflected
  - Example: Global Administrator role has a new privileged permissions related to AI agents
    - Are those permissions in other roles?
    - Can those permissions be added to custom roles?

The Problem

Updates to role permissions not represented



The Problem

Findings and Remediations

- Findings could miss information
  - Role assignment that is scoped (not represented)
  - Custom roles (not represented)
- Remediation and attack information may not be accurate for the finding because of scoping or other factors

- Still need to represent the role assignment as well as the direct connection to the resource for shortest path calculations

The Problem

1. Shortest path calculations
2. Scoped assignments
3. Custom roles
4. Static representation of roles
5. Accurate findings and remediations

The Solution

The Solution – Collection

- Collect every role in the environment
  - Including custom roles
- Collect every role assignment in the environment
  - Including scoped assignments

- AzureHound already does this

The Solution – Role Assignment

- Create a new RoleAssignment node
- Connect the Role to it's corresponding RoleAssignment node
- Connect users who have the role assigned to the RoleAssignment node
- Connect role assignment to the scope of the assignment

- These shows the user has the role assigned

The Solution – Role Assignment

Create a new RoleAssignment node

RoleAssignment

Role

Group

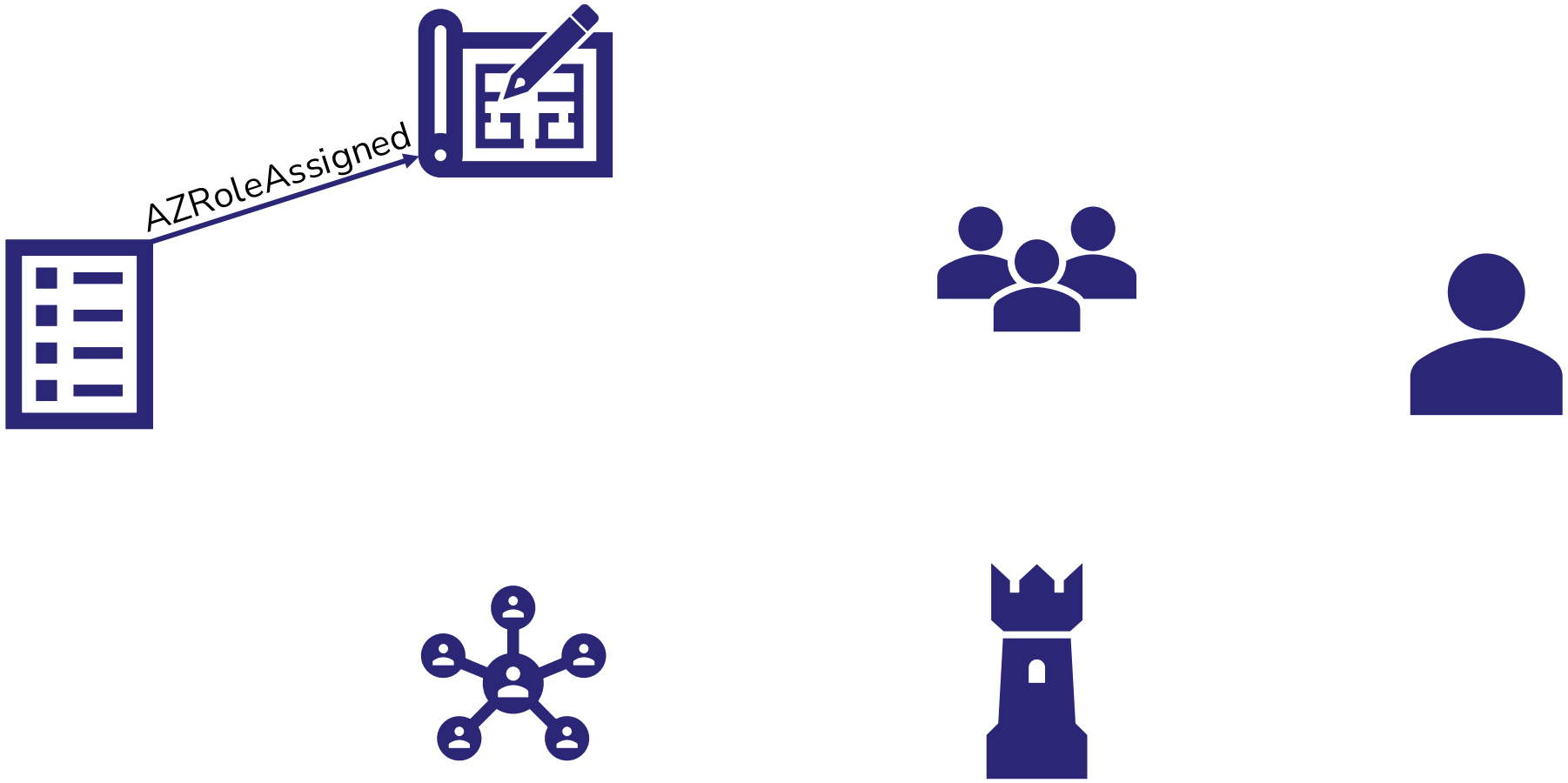
User

Administrative Unit

Tenant

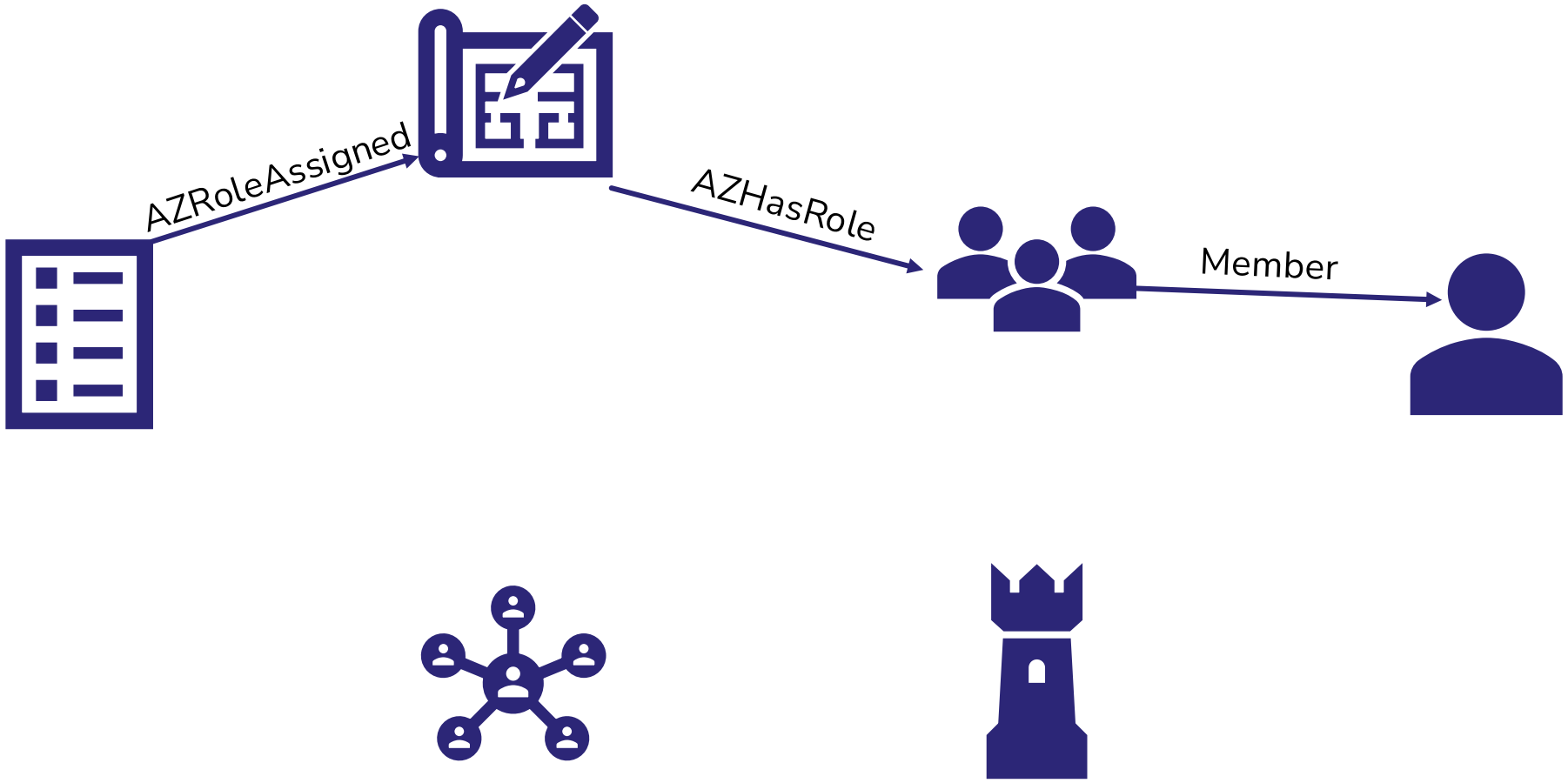
The Solution – Role Assignment

Connect the Role to it's corresponding RoleAssignment node



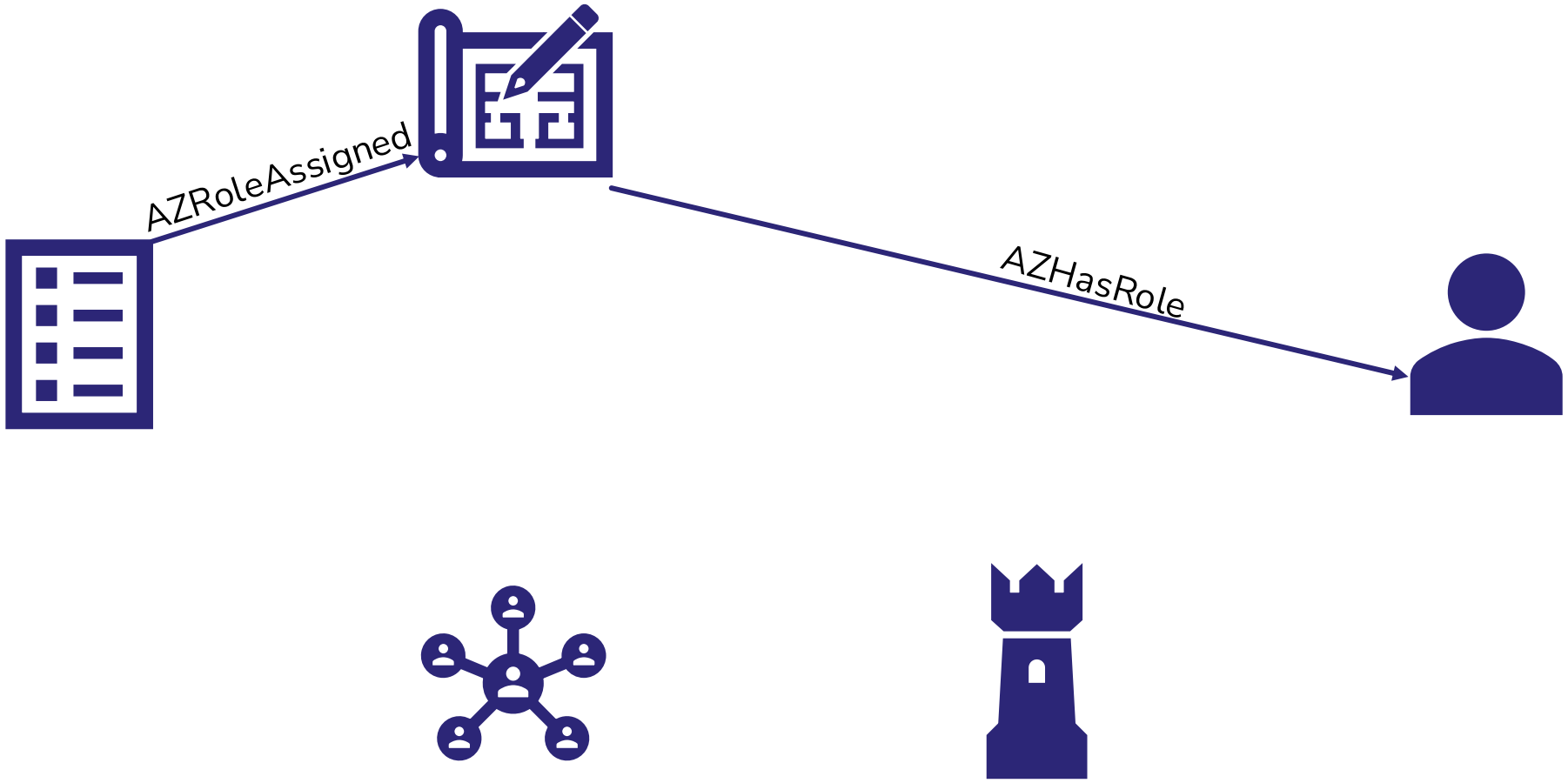
The Solution – Role Assignment

Connect users who have the role assigned to the RoleAssignment node



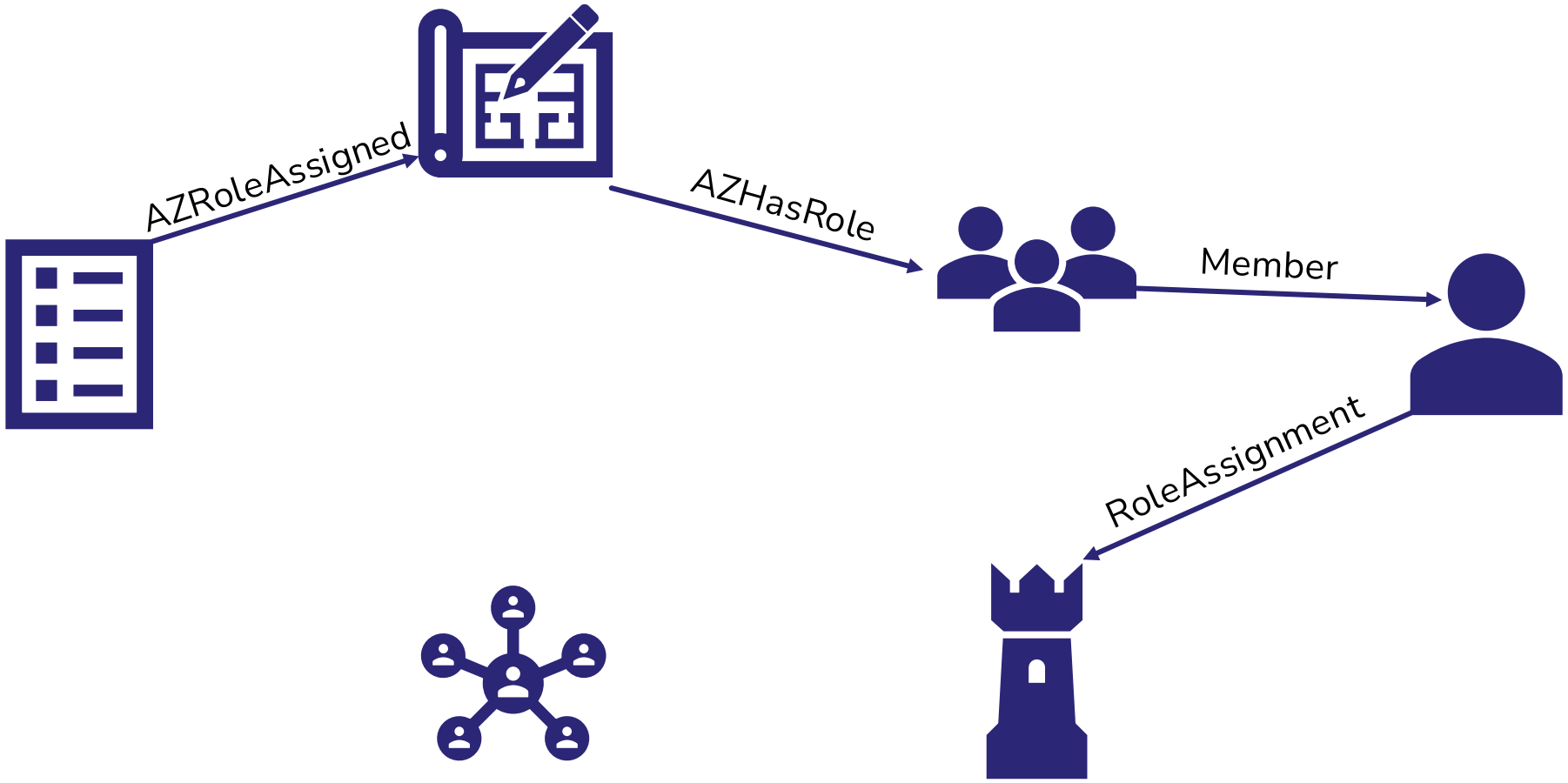
The Solution – Role Assignment

Connect users who have the role assigned to the RoleAssignment node



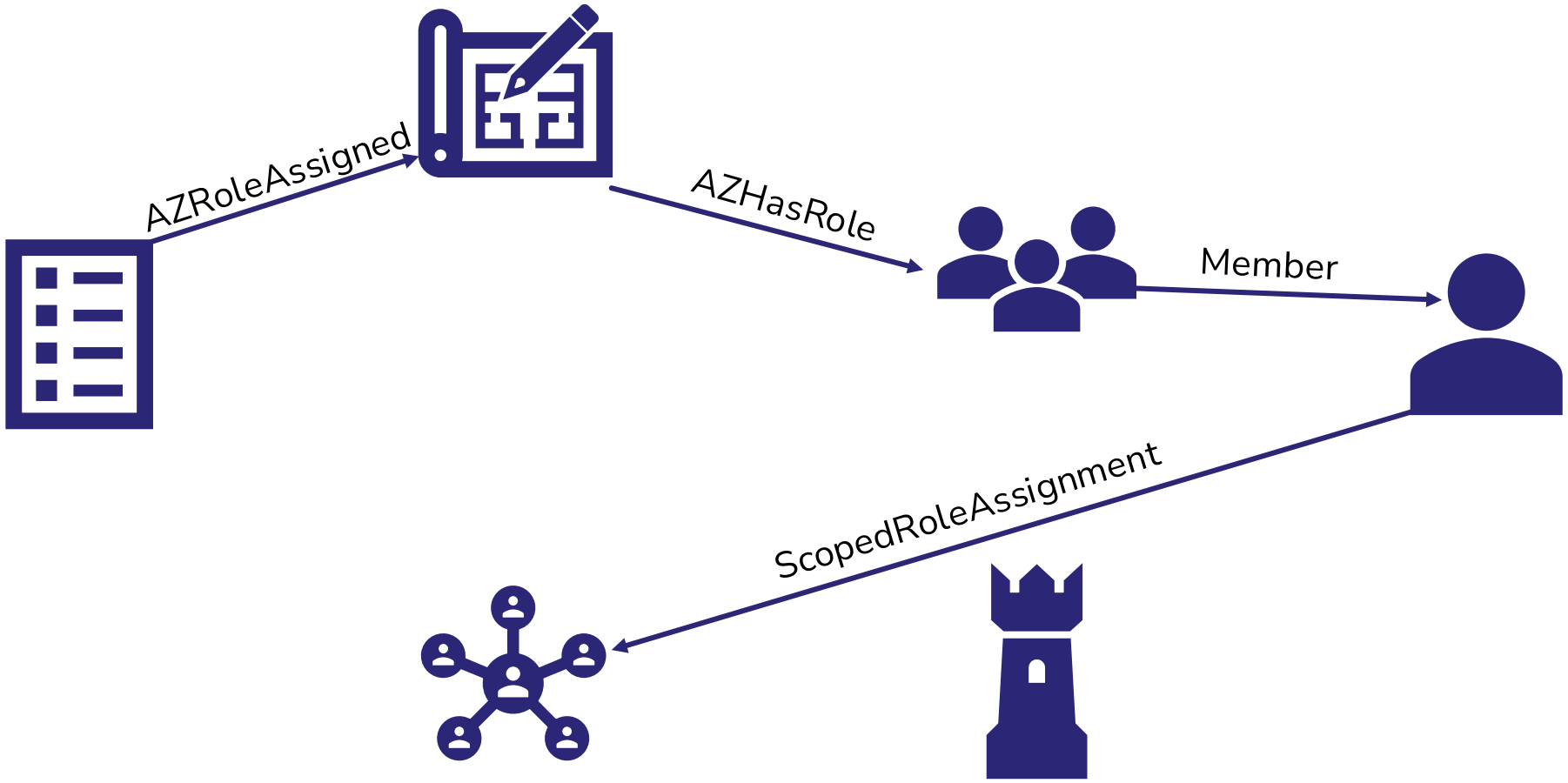
The Solution – Role Assignment

Connect role assignment to the scope of the assignment



The Solution – Role Assignment

Connect role assignment to the scope of the assignment



The Solution – Role Assignment

- Abstracts the role assignment
- Better for shortest path calculations
- Starts to show scoped assignments better
- Preserves information about how the user got permissions
  - Still queryable to find role assignments

The Problem

1. Shortest path calculations ✅
2. Scoped assignments 💡
3. Custom roles
4. Static representation of roles
5. Accurate findings and remediations

The Problem

1. Shortest path calculations ✅
2. Scoped assignments 💡
3. Custom roles ⬅️
4. Static representation of roles ⬅️
5. Accurate findings and remediations

RBAC Refresh

- Role based access control (RBAC)
- Method for access control to resources and data
- Roles are:
  - Based on job function
  - Collection of permissions
  - Assigned to users
  - Enable access and ability to make changes

Entra RBAC

Back again

Role permissions

microsoft.directory/applications/createAsOwner	
microsoft.directory/oAuth2PermissionGrants/createAsOwner	PRIVILEGED
microsoft.directory/servicePrincipals/createAsOwner	

Application Developer | Description

Privileged Identity Management | Microsoft Entra roles

Got feedback?

Summary

Name: Application Developer PRIVILEGED

Description: Users in this role will continue to be able to register app registrations even if the Global Admin has turned off the tenant level switch for "Users can register apps".
This role is considered privileged because one or more of its permissions are privileged. Learn more

Template ID: cf1c38e5-3621-4004-a7cb-879624dced7c

Related articles: Assigning administrator roles in Microsoft Entra ID

Role permissions

microsoft.directory/applications/createAsOwner		Create all types of applications, and creator is added as the first owner
microsoft.directory/oAuth2PermissionGrants/createAsOwner	PRIVILEGED	Create OAuth 2.0 permission grants, with creator as the first owner
microsoft.directory/servicePrincipals/createAsOwner		Create service principals, with creator as the first owner

This role also grants the following basic read permissions to guests and service principals

microsoft.directory/administrativeUnits/members/read	Read members of administrative units
microsoft.directory/administrativeUnits/standard/read	Read basic properties on administrative units
microsoft.directory/applicationPolicies/standard/read	Read standard properties of application policies
microsoft.directory/applications/owners/read	Read owners of applications
microsoft.directory/applications/policies/read	Read policies of applications

The Solution – Permissions

- Store permissions for all roles
- Evaluate individual permissions
- Draw edges based on what the permissions allow
- Collapse edges into a composition edge

The Solution – Permissions

Is it that easy?... No, sorry.

- Requires understanding of what the permission allows
- What resource does this permission affect?
  - Device permissions, application permission, policy permissions, etc.
- What action does the permission allow?
  - Read, create, delete, update, etc.
- Is the edge traversable?
  - Allows for movement, takeover, etc.

The Solution – Permissions

Is it that easy?... No, sorry.

- Can be difficult to start out
- 858 operations for Entra ID roles as of 4/3/2026
  - https://www.azadvertizer.net/azEntraIdRoleActionsAdvertizer.html
- Also have conditions
  - No condition, Self condition, Owner condition
  - In Entra, these can mostly be ignored because they are only for specific roles (User, Owner) and not able to be configured

The Solution – Permissions

Where to start?

- Start with what you know
  - If the role has a known abuse, identify the permission that allows the abuseable action
  - Example:
    - Adding credentials to an application for privilege escalation or persistence
    - *"microsoft.directory/applications/credentials/update"*
    - Edge: EnUpdateAppCredentials

The Solution – Permissions

Where to start?

- 13 read permissions
- 5 delete permissions
- 5 create permissions
- 30 update permissions
- 1 instantiate permission
- 1 restore permission
- 7 all task permission
- 1 disable permission
- 1 enable permission
- 6 manage permissions
- 3 other service principal permissions

Application Admin

73 total permissions


```
"rolePermissions": [
  {
    "allowedResourceActions": [
      "microsoft.azure.serviceHealth/allEntities/allTasks",
      "microsoft.azure.supportTickets/allEntities/allTasks",
      "microsoft.directory/adminConsentRequestPolicy/allProperties/allTasks",
      "microsoft.directory/appConsent/appConsentRequests/allProperties/read",
      "microsoft.directory/applicationPolicies/basic/update",
      "microsoft.directory/applicationPolicies/create",
      "microsoft.directory/applicationPolicies/delete",
      "microsoft.directory/applicationPolicies/owners/read",
      "microsoft.directory/applicationPolicies/owners/update",
      "microsoft.directory/applicationPolicies/policyAppliedTo/read",
      "microsoft.directory/applicationPolicies/standard/read",
      "microsoft.directory/applications/applicationProxyAuthentication/update",
      "microsoft.directory/applications/applicationProxy/read",
      "microsoft.directory/applications/applicationProxySslCertificate/update",
      "microsoft.directory/applications/applicationProxy/update",
      "microsoft.directory/applications/applicationProxyUrlSettings/update",
      "microsoft.directory/applications/appRoles/update",
      "microsoft.directory/applications/audience/update",
      "microsoft.directory/applications/authentication/update",
      "microsoft.directory/applications/basic/update",
      "microsoft.directory/applications/create",
      "microsoft.directory/applications/credentials/update",
      "microsoft.directory/applications/delete",
      "microsoft.directory/applications/disablement/update",
      "microsoft.directory/applications/extensionProperties/update",
      "microsoft.directory/applications/notes/update",
      "microsoft.directory/applications/owners/update",
      "microsoft.directory/applications/permissions/update",
      "microsoft.directory/applications/policies/update",
      "microsoft.directory/applications/synchronization/standard/read",
      "microsoft.directory/applications/tag/update",
      "microsoft.directory/applications/verification/update",
      "microsoft.directory/applicationTemplates/instantiate",
      "microsoft.directory/auditLogs/allProperties/read",
      "microsoft.directory/connectorGroups/allProperties/read",
      "microsoft.directory/connectorGroups/allProperties/update",
      "microsoft.directory/connectorGroups/create",
      "microsoft.directory/connectorGroups/delete",
      "microsoft.directory/connectors/allProperties/read",
      "microsoft.directory/connectors/create",
      "microsoft.directory/customAuthenticationExtensions/allProperties/allTasks",
      "microsoft.directory/deletedItems.applications/delete",
      "microsoft.directory/deletedItems.applications/restore",
      "microsoft.directory/oAuth2PermissionGrants/allProperties/allTasks",
      "microsoft.directory/provisioningLogs/allProperties/read",
      "microsoft.directory/servicePrincipals/appRoleAssignedTo/update",
      "microsoft.directory/servicePrincipals/audience/update",
      "microsoft.directory/servicePrincipals/authentication/update",
      "microsoft.directory/servicePrincipals/basic/update",
      "microsoft.directory/servicePrincipals/create",
      "microsoft.directory/servicePrincipals/credentials/update",
      "microsoft.directory/servicePrincipals/delete",
      "microsoft.directory/servicePrincipals/disable",
      "microsoft.directory/servicePrincipals/enable",
      "microsoft.directory/servicePrincipals/getPasswordSingleSignOnCredentials",
      "microsoft.directory/servicePrincipals/managePasswordSingleSignOnCredentials",
      "microsoft.directory/servicePrincipals/managePermissionGrantsForAll.microsoft-application-admin",
      "microsoft.directory/servicePrincipals/notes/update",
      "microsoft.directory/servicePrincipals/owners/update",
      "microsoft.directory/servicePrincipals/permissions/update",
      "microsoft.directory/servicePrincipals/policies/update",
      "microsoft.directory/servicePrincipals/synchronization.cloudTenantToExternalSystem/credentials/manage",
      "microsoft.directory/servicePrincipals/synchronization.cloudTenantToExternalSystem/jobs/manage",
      "microsoft.directory/servicePrincipals/synchronization.cloudTenantToExternalSystem/schema/manage",
      "microsoft.directory/servicePrincipals/synchronizationCredentials/manage",
      "microsoft.directory/servicePrincipals/synchronizationJobs/manage",
      "microsoft.directory/servicePrincipals/synchronizationSchema/manage",
      "microsoft.directory/servicePrincipals/synchronization/standard/read",
      "microsoft.directory/servicePrincipals/tag/update",
      "microsoft.directory/signInReports/allProperties/read",
      "microsoft.office365.serviceHealth/allEntities/allTasks",
      "microsoft.office365.supportTickets/allEntities/allTasks",
      "microsoft.office365.webPortal/allEntities/standard/read"
    ],
```

The Solution – Permissions

How many actually matter?

- ~~13 read permissions~~
- ~~5 delete permissions~~
- 5 create permissions -> 3 to map
- 30 update permissions -> 9 to map
- ~~1 instantiate permission~~
- ~~1 restore permission~~
- 7 all task permission -> 2 to map
- ~~1 disable permission~~
- 1 enable permission -> 1 to map
- 6 manage permissions -> 2 to map
- 3 other service principal permissions -> 3 to map

Application Admin

21 total permissions


```
"rolePermissions": [
  {
    "allowedResourceActions": [
      "microsoft.azure.serviceHealth/allEntities/allTasks",
      "microsoft.azure.supportTickets/allEntities/allTasks",
      "microsoft.directory/adminConsentRequestPolicy/allProperties/allTasks",
      "microsoft.directory/appConsent/appConsentRequests/allProperties/read",
      "microsoft.directory/applicationPolicies/basic/update",
      "microsoft.directory/applicationPolicies/create",
      "microsoft.directory/applicationPolicies/delete",
      "microsoft.directory/applicationPolicies/owners/read",
      "microsoft.directory/applicationPolicies/owners/update",
      "microsoft.directory/applicationPolicies/policyAppliedTo/read",
      "microsoft.directory/applicationPolicies/standard/read",
      "microsoft.directory/applications/applicationProxyAuthentication/update",
      "microsoft.directory/applications/applicationProxy/read",
      "microsoft.directory/applications/applicationProxySslCertificate/update",
      "microsoft.directory/applications/applicationProxy/update",
      "microsoft.directory/applications/applicationProxyUrlSettings/update",
      "microsoft.directory/applications/appRoles/update",
      "microsoft.directory/applications/audience/update",
      "microsoft.directory/applications/authentication/update",
      "microsoft.directory/applications/basic/update",
      "microsoft.directory/applications/create",
      "microsoft.directory/applications/credentials/update",
      "microsoft.directory/applications/delete",
      "microsoft.directory/applications/disablement/update",
      "microsoft.directory/applications/extensionProperties/update",
      "microsoft.directory/applications/notes/update",
      "microsoft.directory/applications/owners/update",
      "microsoft.directory/applications/permissions/update",
      "microsoft.directory/applications/policies/update",
      "microsoft.directory/applications/synchronization/standard/read",
      "microsoft.directory/applications/tag/update",
      "microsoft.directory/applications/verification/update",
      "microsoft.directory/applicationTemplates/instantiate",
      "microsoft.directory/auditLogs/allProperties/read",
      "microsoft.directory/connectorGroups/allProperties/read",
      "microsoft.directory/connectorGroups/allProperties/update",
      "microsoft.directory/connectorGroups/create",
      "microsoft.directory/connectorGroups/delete",
      "microsoft.directory/connectors/allProperties/read",
      "microsoft.directory/connectors/create",
      "microsoft.directory/customAuthenticationExtensions/allProperties/allTasks",
      "microsoft.directory/deletedItems.applications/delete",
      "microsoft.directory/deletedItems.applications/restore",
      "microsoft.directory/oAuth2PermissionGrants/allProperties/allTasks",
      "microsoft.directory/provisioningLogs/allProperties/read",
      "microsoft.directory/servicePrincipals/appRoleAssignedTo/update",
      "microsoft.directory/servicePrincipals/audience/update",
      "microsoft.directory/servicePrincipals/authentication/update",
      "microsoft.directory/servicePrincipals/basic/update",
      "microsoft.directory/servicePrincipals/create",
      "microsoft.directory/servicePrincipals/credentials/update",
      "microsoft.directory/servicePrincipals/delete",
      "microsoft.directory/servicePrincipals/disable",
      "microsoft.directory/servicePrincipals/enable",
      "microsoft.directory/servicePrincipals/getPasswordSingleSignOnCredentials",
      "microsoft.directory/servicePrincipals/managePasswordSingleSignOnCredentials",
      "microsoft.directory/servicePrincipals/managePermissionGrantsForAll.microsoft-application-admin",
      "microsoft.directory/servicePrincipals/notes/update",
      "microsoft.directory/servicePrincipals/owners/update",
      "microsoft.directory/servicePrincipals/permissions/update",
      "microsoft.directory/servicePrincipals/policies/update",
      "microsoft.directory/servicePrincipals/synchronization.cloudTenantToExternalSystem/credentials/manage",
      "microsoft.directory/servicePrincipals/synchronization.cloudTenantToExternalSystem/jobs/manage",
      "microsoft.directory/servicePrincipals/synchronization.cloudTenantToExternalSystem/schema/manage",
      "microsoft.directory/servicePrincipals/synchronizationCredentials/manage",
      "microsoft.directory/servicePrincipals/synchronizationJobs/manage",
      "microsoft.directory/servicePrincipals/synchronizationSchema/manage",
      "microsoft.directory/servicePrincipals/synchronization/standard/read",
      "microsoft.directory/servicePrincipals/tag/update",
      "microsoft.directory/signInReports/allProperties/read",
      "microsoft.office365.serviceHealth/allEntities/allTasks",
      "microsoft.office365.supportTickets/allEntities/allTasks",
      "microsoft.office365.webPortal/allEntities/standard/read"
    ],
```

The Solution – Permissions

Ok, not so bad

- This can be lowered even more if you are starting with only traversable edges
- Not every permission will need to have an edge
- This is just the beginning though
  - Eventually, you will want to make sure it is robust enough to give an accurate picture
  - Attack VS Access Graphs

The Solution – Edges

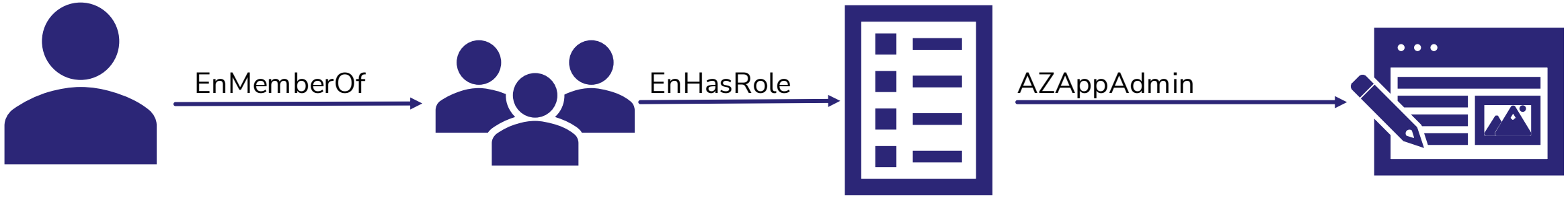
Making the connection

- Connect the principal assigned the role directly to the relevant resource
- Example:
  - User assigned via group membership Application Administrator
  - Permission: *"microsoft.directory/applications/credentials/update"*
  - EnUser -EnUpdateAppCredentials-> EnApplication

The Solution – Edges

Comparison to previous method

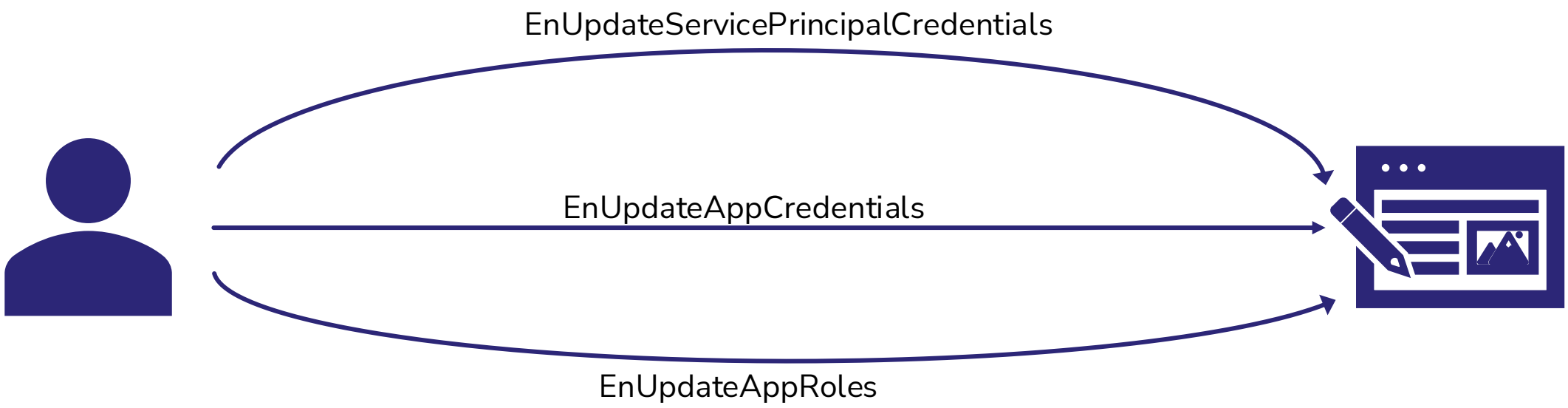
Old



New

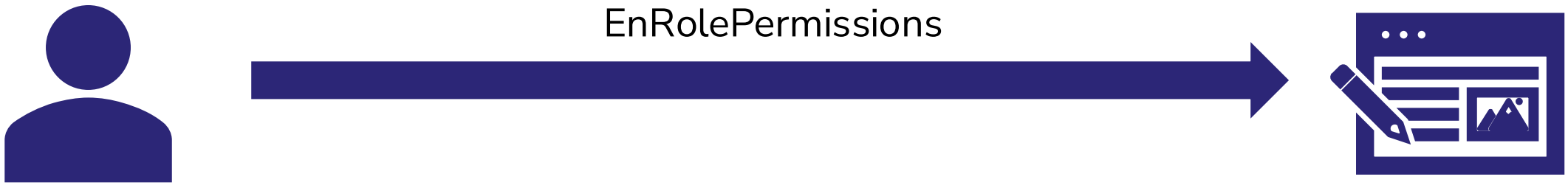
The Solution – Composition Edges

Multiple Edges



The Solution – Edges

Multiple Edges



The Solution – Composition Edges

Benefits

- Same permissions appear in multiple built-in roles
  - Create the logic for the permission once
  - Will apply to every role with that permission
- Covers custom roles
  - If permission is used in a custom role, that will be mapped now
- Direct connection to resource
  - More accurate shortest path calculation

The Solution – Composition Edges

Benefits

- Can update individual permissions
  - Discovery of new tradecraft requires one update
  - Less searching for every role that has the permission
- Multiple attack primitives
  - More accurately shows that a single role can have more than one possible attack

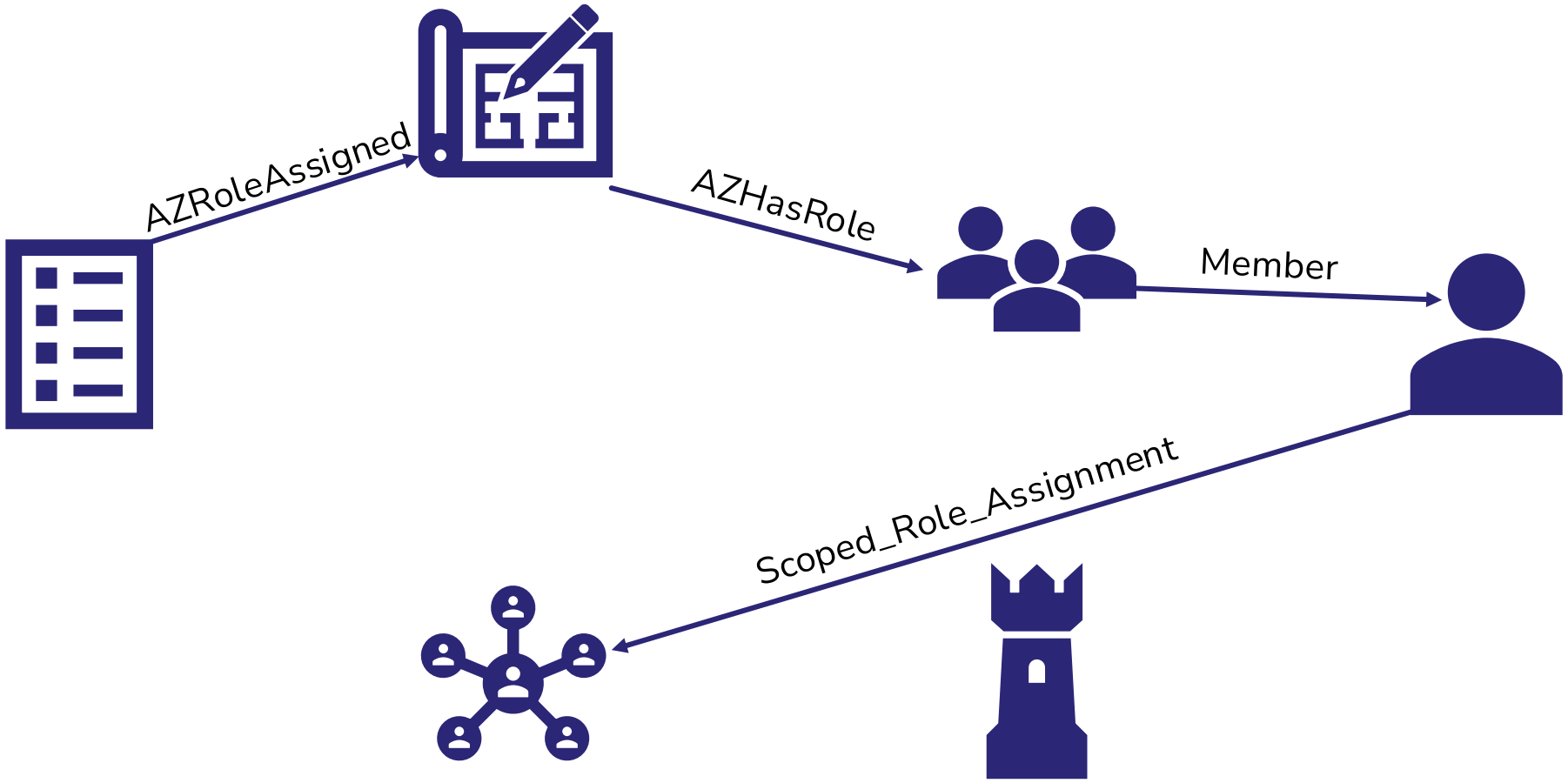
The Problem

1. Shortest path calculations ✅
2. Scoped assignments 💡
3. Custom roles ✅
4. Static representation of roles ✅
5. Accurate findings and remediations

The Solution – Scoping

- Not all role assignments are for everything
  - Scoped assignments must be considered and reflected in the modeling
- Evaluation should be for the scope then the permissions within the role

The Solution – Role Assignment



Example – Entra ID

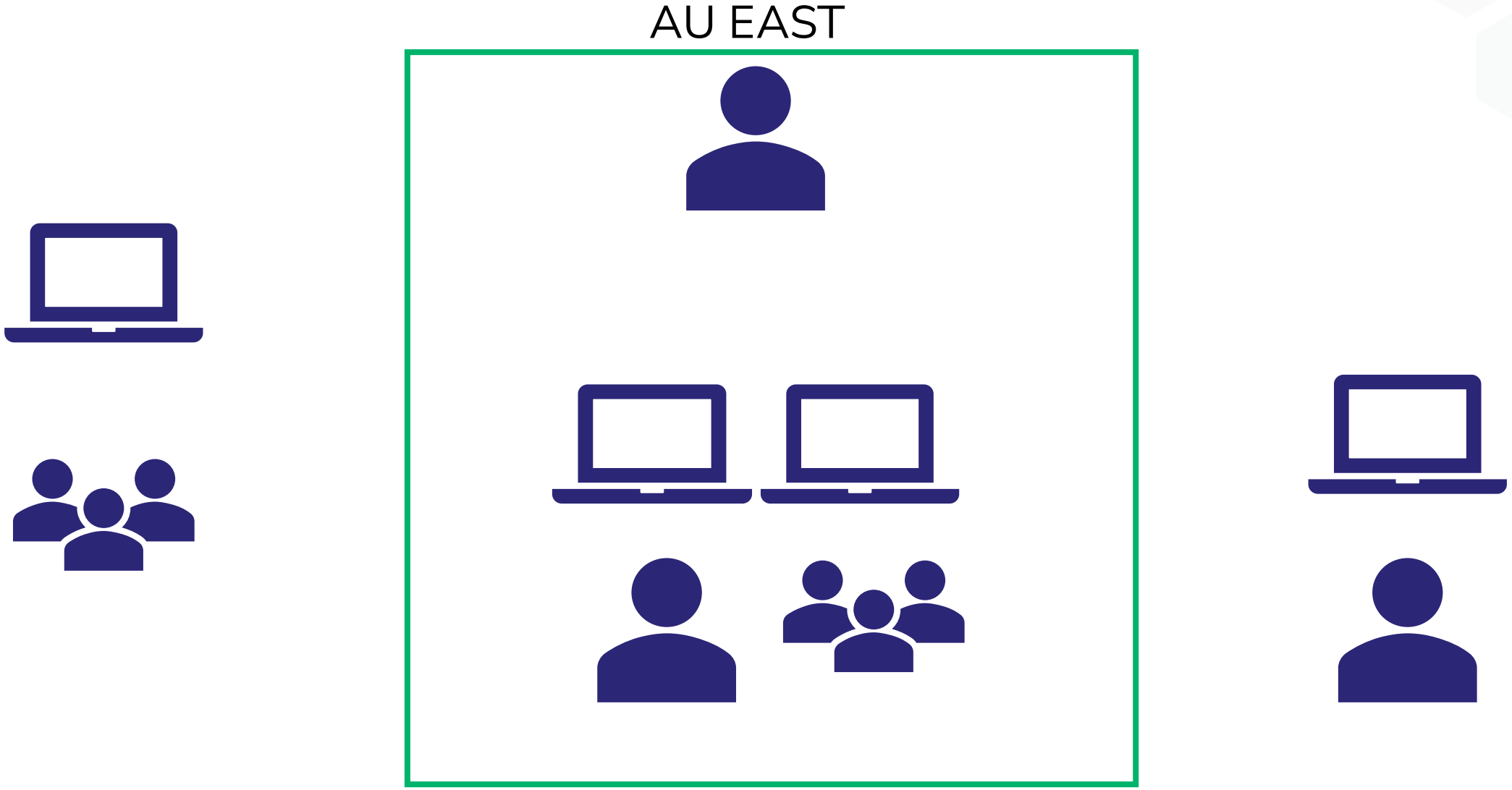
- Full directory assignments
  - Most common, but not reflective of everything
- Scoped assignments
  - Administrative units
    - When a role is assigned within an AU, it only applies to objects within the AU
  - Application/service principal
    - Applies only to a single app or SP

The Solution – Scoped Assignments

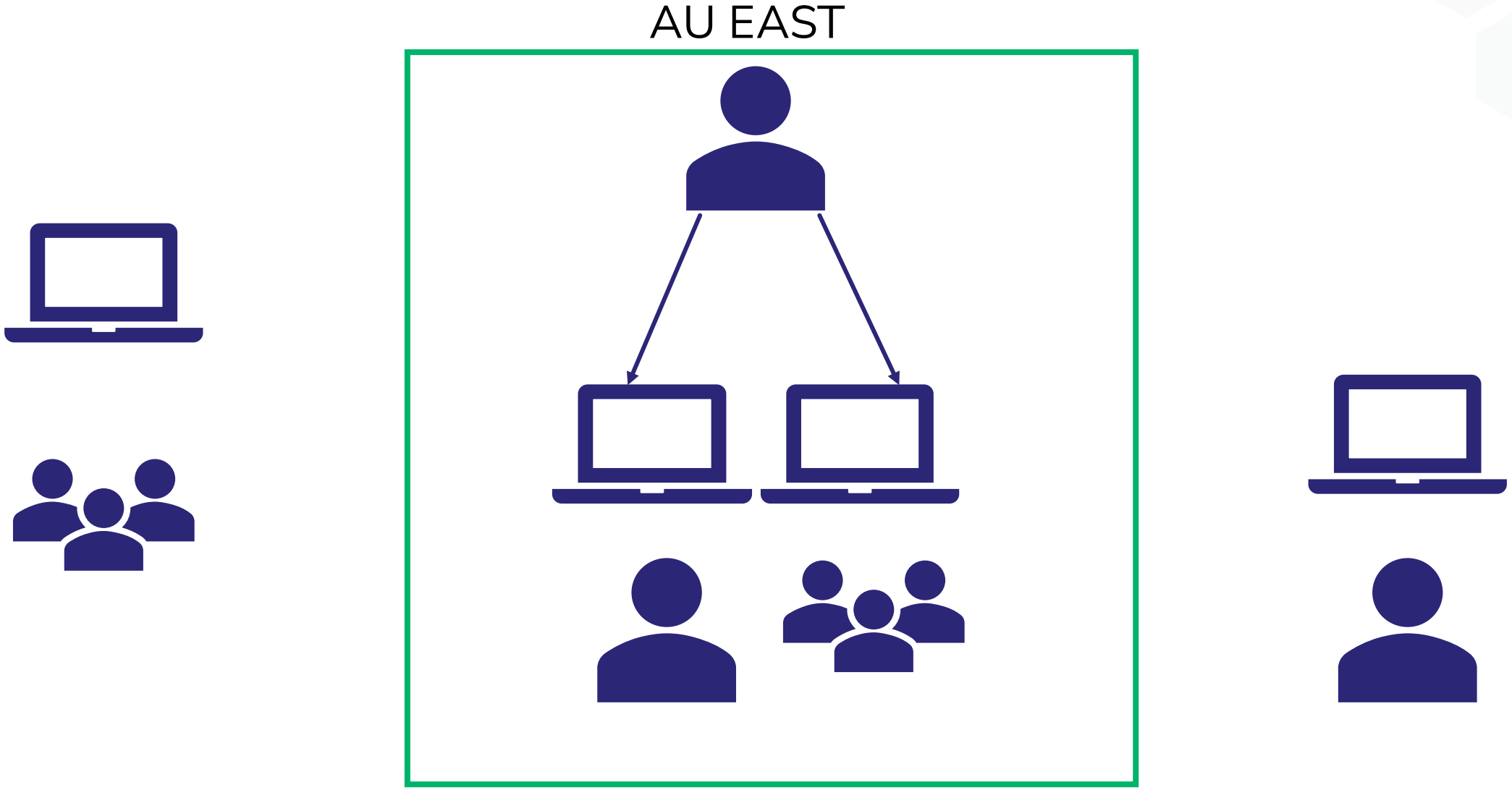
- Connect the principal to the resources in the scope only
- Permission must match the resource type
- Example:
  - AU with users, groups, and devices
  - Permission: *microsoft.directory/deviceLocalCredentials/password/read*
  - Edges connect user to only devices in the AU

The Solution – Scoped Assignments

The Solution – Scoped Assignments



The Solution – Scoped Assignments



The Problem

1. Shortest path calculations ✅
2. Scoped assignments ✅
3. Custom roles ✅
4. Static representation of roles ✅
5. Accurate findings and remediations

The Problem

1. Shortest path calculations ✅
2. Scoped assignments ✅
3. Custom roles ✅
4. Static representation of roles ✅
5. Accurate findings and remediations ✅

Final Thoughts

Long-term Vision

- These are living systems that are subject to changes frequently
- Goals are to provide an approach that is:
  - Repeatable across multiple RBAC instantiations
  - Easier to update as changes occur
  - Accounts for the full picture of permissions

Where is this at now?

Current State

- Not implemented yet
  - First round of research done and documented
- Subject to change as engineering works on it
  - Refinement of the exact implementation
- This is how we want all RBAC models to work
  - More long-term sustainability and easier to update as changes occur

Thank you